



MCP Security Audit Report

AgentSign

notebooklm-mcp-cli

28 September 2026

Report ID: MCPS-MUKNIJAZ

Executive Summary

FAIL

Risk Score

100/100

10
CRITICAL

133
HIGH

473
MEDIUM

4
LOW

SCAN SCOPE 252 files 71,926 lines	LANGUAGES json (1), python (251)	MCPS SDK Not Found
---	-------------------------------------	-----------------------

Risk Comparison: WITHOUT MCPS vs WITH MCPS

CURRENT EXPOSURE			WITH MCPS PROTECTION		
MCP-01	Rug Pulls Vulnerable pattern detected, no mitigation	●	MITIGATED Passport identity binding — tools are tied to verified agent identity <code>createPassport()</code> , <code>signPassport()</code>		●
MCP-03	Privilege Escalation via Tool Composition Vulnerable pattern detected, no mitigation	●	MITIGATED Tool integrity signing — each tool definition is cryptographically signed <code>signTool()</code> , <code>verifyTool()</code>		●
MCP-04	Cross-Server Request Forgery Vulnerable pattern detected, no mitigation	●	MITIGATED Signed tool definitions prevent tampering during cross-server calls <code>signTool()</code> , <code>tool_hash</code>		●
MCP-06	Indirect Prompt Injection via MCP MCPS mitigation detected	●	MITIGATED Signed message envelopes — all MCP messages carry cryptographic signatures <code>signMessage()</code> , <code>verifyMessage()</code>		●
MCP-07	Resource Exhaustion & DoS MCPS mitigation detected	●	MITIGATED Passport verification middleware — all requests require valid signed identity <code>secureMCP()</code> , <code>verifyPassport()</code>		●
MCP-08	Insufficient Logging & Audit Vulnerable pattern detected, no mitigation	●	MITIGATED Signed audit trail — every message exchange is logged with cryptographic proof <code>auditLog()</code> , <code>onAudit()</code>		●
MCP-09	Insecure MCP-to-MCP Communication MCPS mitigation detected	●	MITIGATED Origin binding — passports encode allowed origins, verified on each request <code>validateOrigin()</code> , <code>passport.origin</code>		●
MCP-10	Context Window Pollution MCPS mitigation detected	●	MITIGATED Envelope isolation — signed message boundaries prevent context pollution <code>signMessage()</code> , <code>envelope</code>		●

Risk Reduction

100 --> 100

OWASP MCP Top 10 Compliance

Coverage: 4/8 risks mitigated by MCPS

ID	Risk	Status	Current State	With MCPS
MCP-01	Rug Pulls	FAIL	Vulnerable pattern detected, no mitigation	Passport identity binding — tools are tied to verified agent identity
MCP-02	Tool Poisoning	N/A	Not applicable to code-level analysis	N/A — requires LLM-level defense
MCP-03	Privilege Escalation via Tool Composition	FAIL	Vulnerable pattern detected, no mitigation	Tool integrity signing — each tool definition is cryptographically signed
MCP-04	Cross-Server Request Forgery	FAIL	Vulnerable pattern detected, no mitigation	Signed tool definitions prevent tampering during cross-server calls
MCP-05	Sampling Manipulation	N/A	Not applicable to code-level analysis	N/A — requires client-level defense
MCP-06	Indirect Prompt Injection via MCP	PASS	MCPS mitigation detected	Signed message envelopes — all MCP messages carry cryptographic signatures
MCP-07	Resource Exhaustion & DoS	PASS	MCPS mitigation detected	Passport verification middleware — all requests require valid signed identity
MCP-08	Insufficient Logging & Audit	FAIL	Vulnerable pattern detected, no mitigation	Signed audit trail — every message exchange is logged with cryptographic proof
MCP-09	Insecure MCP-to-MCP Communication	PASS	MCPS mitigation detected	Origin binding — passports encode allowed origins, verified on each request
MCP-10	Context Window Pollution	PASS	MCPS mitigation detected	Envelope isolation — signed message boundaries prevent context pollution

Quick Fix `npm install mcp-secure`

Add MCPS to your MCP server to automatically mitigate the risks marked FAIL above.

OWASP Agentic AI Top 10 Coverage

12 rules checked | 620 findings

Rule	OWASP	MITRE	STRIDE	Severity	Findings	Status
AS-001	AA-03	T1059	Elevation of Privilege	CRITICAL	7	●
AS-002	AA-05	T1552	Information Disclosure	HIGH	31	●
AS-003	AA-04	T1078	Elevation of Privilege	MEDIUM	250	●
AS-004	AA-02	T1190	Tampering	HIGH	27	●
AS-005	AA-02	T1055	Tampering	CRITICAL	3	●
AS-006	AA-09	T1610	Elevation of Privilege	HIGH	1	●
AS-007	AA-06	T1195	Tampering	LOW	4	●
AS-008	AA-01	T1548	Elevation of Privilege	HIGH	36	●
AS-009	AA-07	T1059.007	Tampering	MEDIUM	0	●
AS-010	AA-08	T1562.002	Repudiation	MEDIUM	223	●
AS-011	AA-10	T1041	Information Disclosure	HIGH	38	●
AS-012	MCP-07	T1078.004	Spoofing	HIGH	0	●

Detailed Findings

#1 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

`desktop-extension/run_server.py:54`

Dependency without integrity verification

```
52 |         os.path.join(home, "scoop", "shims", "uvx.exe"),
53 |     ]
> 54 |     # `pip install --user uv` places uvx.exe in
55 |     # %APPDATA%\Python\Python3XX\Scripts, which Windows does not add to PATH...
56 |     # automatically, so shutil.which() above misses it. Include the Scripts
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#2 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`desktop-extension/run_server.py:1`

No logging, auditing, or monitoring detected

```
> 1 | #!/usr/bin/env python3
2 | """Robust launcher for the Gemini Notebook MCP Server in Claude Desktop.
3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#3 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`scripts/build_mcpb.py:1`

No logging, auditing, or monitoring detected

```
> 1 | #!/usr/bin/env python3
2 | """Build the .mcpb extension package for Claude Desktop.
3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#4 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[scripts/inject_cookies_and_inspect.py:121](#)

Dangerous execution: (async function) {

```
119 |         {
120 |             "expression": ""
> 121 |         (async function() {
122 |             function sleep(ms) { return new Promise(resolve => setTimeout(resolve, ms)); }...
123 |     }
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#5 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[scripts/inject_cookies_and_inspect.py:172](#)

Dangerous execution: (async function) {

```
170 |         {
171 |             "expression": ""
> 172 |         (async function() {
173 |             function sleep(ms) { return new Promise(resolve => setTimeout(resolve, ms)); }
174 |     }
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#6 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[scripts/inspect_upload_dom.py:104](#)

Dangerous execution: (function) {

```
102 |         {
103 |             "expression": ""
> 104 |         (function() {
105 |             const walker = document.createTreeWalker(document.body, NodeFilter.SHOW_TEXT);
106 |             const matches = [];
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#7 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[scripts/inspect_upload_dom.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """
2 | Script to inspect NotebookLM DOM for file upload selectors.
3 | """
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include `agent_id`, `timestamp`, `action`, `parameters`, and `outcome` in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#8 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[scripts/test_label_rpc.py:48](#)

High-risk permission pattern: `RPC_LABEL_DELETE = "GyzE7e"` # delete one or many labels

```
46 |     RPC_LABEL_MANAGE = "agX4Bc" # auto-label + create + list
47 |     RPC_LABEL_MUTATE = "le8sX" # rename + emoji + move source
> 48 |     RPC_LABEL_DELETE = "GyzE7e" # delete one or many labels
49 |     RPC_USER_TIER = "ozz5Z" # get subscription tier (fires on page load)...
50 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#9 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[scripts/test_label_rpc.py:100](#)

High-risk permission pattern: `""Delete one or more labels (sources are preserved).""`

```
98 |
99 |     def delete_labels(self, notebook_id: str, label_ids: list[str]) -> bool:
> 100 |         ""Delete one or more labels (sources are preserved).""
101 |         params = [[2], notebook_id, label_ids]
102 |         result = self._call_rpc(
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#10 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[scripts/test_label_rpc.py:205](#)

High-risk permission pattern: `section("6. DELETE LABEL (cleanup)")`

```
203 |         print(" (skipped – need 2+ labels and at least 1 source)")
204 |
> 205 |     section("6. DELETE LABEL (cleanup)")
206 |     if created_label_id:
207 |         try:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#11 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[scripts/test_label_rpc.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | #!/usr/bin/env python3
2 | """POC test script for label management RPCs.
3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#12 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/__init__.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """NotebookLM Tools - Unified CLI and MCP server for Google NotebookLM."""
  2 | ...
  3 | from __future__ import annotations
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#13 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/cli/__init__.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """CLI interface for NotebookLM."""
  2 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#14 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/ai_docs.py:95](#)

High-risk permission pattern: | `nlm notebook` | Manage notebooks (list, create, get, describe, rename, delete)

```
93 | | `nlm usage` | Show rolling and weekly plan usage, reset times, and subscription tier |
94 | | `nlm config` | View/edit configuration (show, get, set) |
> 95 | | `nlm notebook` | Manage notebooks (list, create, get, describe, rename, delete, query) |
96 | | `nlm source` | Manage sources (list, add, get, describe, content, rename, delete, stale, sync) |
97 | | `nlm chat` | Chat with notebooks (start, configure) |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#15 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/ai_docs.py:96](#)

High-risk permission pattern: | `nlm source` | Manage sources (list, add, get, describe, content, rename, delete)

```
94 | | `nlm config` | View/edit configuration (show, get, set) |
95 | | `nlm notebook` | Manage notebooks (list, create, get, describe, rename, delete, query) |
> 96 | | `nlm source` | Manage sources (list, add, get, describe, content, rename, delete, stale, sync) |
97 | | `nlm chat` | Chat with notebooks (start, configure) |
98 | | `nlm studio` | Manage artifacts (status, delete) |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#16 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/ai_docs.py:98](#)

High-risk permission pattern: | `nlm studio` | Manage artifacts (status, delete) |

```
96 | | `nlm source` | Manage sources (list, add, get, describe, content, rename, delete, stale, sync) |
97 | | `nlm chat` | Chat with notebooks (start, configure) |
> 98 | | `nlm studio` | Manage artifacts (status, delete) |
99 | | `nlm research` | Research and discover sources (start, status, import) |...
100 | | `nlm alias` | Manage ID shortcuts (set, get, list, delete) |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#17 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/ai_docs.py:100](#)

High-risk permission pattern: | `nlm alias` | Manage ID shortcuts (set, get, list, delete) |

```
98 | | `nlm studio` | Manage artifacts (status, delete) |
99 | | `nlm research` | Research and discover sources (start, status, import) |
> 100 | | `nlm alias` | Manage ID shortcuts (set, get, list, delete) |
101 | | `nlm download` | Download artifacts (audio, video, report, mind-map, slides, infographic, data-
table) |
102 | | `nlm audio` | Create audio overviews/podcasts (create) |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#18 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/ai_docs.py:112](#)

High-risk permission pattern: | `nlm batch` | Batch operations across multiple notebooks (query, add-source, c

```
110 | | `nlm data-table` | Create data tables (create) |
111 | | `nlm share` | Manage notebook sharing (status, public, private, invite) |
> 112 | | `nlm batch` | Batch operations across multiple notebooks (query, add-source, create, delete,
studio) |
113 | | `nlm cross` | Cross-notebook aggregated query (query) |
114 | | `nlm pipeline` | Multi-step notebook workflows (list, run) |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#19 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/ai_docs.py:127](#)

High-risk permission pattern: | `nlm delete` | Delete resources (notebook, source, artifact, alias) |

```
125 | | `nlm list` | List resources (notebooks, sources, artifacts, aliases, stale-sources) |
126 | | `nlm get` | Get details (notebook, source, config, alias) |
> 127 | | `nlm delete` | Delete resources (notebook, source, artifact, alias) |
128 | | `nlm add` | Add sources (url, text, drive) |
129 | | `nlm describe` | Get AI summaries (notebook, source) |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#20 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/ai_docs.py:163](#)

High-risk permission pattern: nlm alias delete myproject # Remove

```
161 | nlm alias list           # List all
162 | nlm alias get myproject  # Resolve to UUID
> 163 | nlm alias delete myproject # Remove
164 | ...
165 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#21 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/ai_docs.py:180](#)

High-risk permission pattern: nlm login profile delete <name> # Delete a profile

```
178 | nlm login switch <profile> # Switch the default profile
179 | nlm login profile list     # List all profiles with email addresses
> 180 | nlm login profile delete <name> # Delete a profile
181 | nlm login profile rename <old> <new> # Rename a profile
182 | nlm auth refresh          # Non-interactive headless refresh (unattended/schedulers)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#22 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/ai_docs.py:218](#)

High-risk permission pattern: nlm notebook delete <id> --confirm --json # Structured deletion result

```
216 | nlm notebook describe <id> --json # JSON output
217 | nlm notebook rename <id> "New Title" # Rename notebook
> 218 | nlm notebook delete <id> --confirm --json # Structured deletion result
219 | nlm notebook query <id> "question" # Chat with sources
220 | nlm notebook query <id> "question" --json # JSON output
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#23 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/ai_docs.py:232](#)

High-risk permission pattern: `nlm delete notebook <id> --confirm` # Delete permanently

```
230 | nlm describe notebook <id>           # AI summary with topics
231 | nlm rename notebook <id> "New Title"  # Rename notebook
> 232 | nlm delete notebook <id> --confirm  # Delete permanently
233 | nlm query notebook <id> "question"    # Chat with sources...
234 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#24 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/ai_docs.py:267](#)

High-risk permission pattern: `nlm source delete <source-id> --confirm --json` # Structured deletion result

```
265 | nlm source content <source-id> --output file.txt # Export to file
266 | nlm source rename <source-id> "New Title" --notebook <notebook-id> # Rename source
> 267 | nlm source delete <source-id> --confirm --json # Structured deletion result
268 | nlm source stale <notebook-id>                 # List stale Drive sources
269 | nlm source sync <notebook-id> --confirm         # Sync all stale
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#25 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/ai_docs.py:285](#)

High-risk permission pattern: `nlm delete source <source-id> --confirm` # Delete source

```
283 | nlm content source <source-id>          # Raw text content
284 | nlm rename source <source-id> "New Title" --notebook <notebook-id> # Rename source
> 285 | nlm delete source <source-id> --confirm # Delete source
286 | nlm list stale-sources <notebook-id>     # List stale Drive sources
287 | nlm stale sources <notebook-id>         # Alternative: list stale sources
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#26 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/ai_docs.py:545](#)

High-risk permission pattern: `nlm studio delete <notebook-id> <artifact-id> --confirm` # Delete artifact

```
543 | nlm studio status <notebook-id> --json --mcp-compatible # MCP-shaped, paginated JSON
544 | nlm video list <notebook-id>                             # List video artifacts only
> 545 | nlm studio delete <notebook-id> <artifact-id> --confirm # Delete artifact
546 | nlm slides revise <artifact-id> --slide '1 instruction' --confirm # Revise slides
547 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#27 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/ai_docs.py:553](#)

High-risk permission pattern: `nlm delete artifact <notebook-id> <artifact-id> --confirm` # Delete artifact

```
551 | nlm status artifacts <notebook-id>          # List all artifacts + status
> 552 | nlm status artifacts <notebook-id> --full  # All details
    553 | nlm delete artifact <notebook-id> <artifact-id> --confirm # Delete artifact
    554 | ` ` `
    555 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#28 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/ai_docs.py:627](#)

High-risk permission pattern: `nlm alias delete <name>` # Remove (no `--confirm` needed)

```
625 | nlm alias get <name>          # Get UUID for alias
> 626 | nlm alias list            # List all aliases
    627 | nlm alias delete <name>      # Remove (no --confirm needed)
    628 | ` ` `
    629 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#29 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/ai_docs.py:636](#)

High-risk permission pattern: `nlm delete alias <name>` # Remove alias

```
634 | nlm list aliases          # List all aliases
> 635 | nlm show aliases        # Alternative: show all aliases
    636 | nlm delete alias <name>  # Remove alias
    637 | ` ` `
    638 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#30 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/ai_docs.py:672](#)

High-risk permission pattern: `nlm batch delete --notebooks "id1,id2" --confirm`

```
670 |  
671 | nlm batch create "Project A, Project B, Project C"          # Create multiple  
> 672 | nlm batch delete --notebooks "id1,id2" --confirm  
673 | nlm batch studio audio --tags "research"..  
674 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#31 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/ai_docs.py:885](#)

High-risk permission pattern: `--json` | JSON output (for parsing/piping) | list, get, describe, query, cont`

```
883 | |-----|-----|-----|  
884 | | (none) | Rich table (human-readable) | All |  
> 885 | | `--json` | JSON output (for parsing/piping) | list, get, describe, query, content, status, usage,  
source add/delete, notebook delete, Studio create |  
886 | | `--quiet` | IDs only (for piping) | list |  
887 | | `--title` | "ID: Title" format | notebook list |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#32 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/ai_docs.py:1045](#)

High-risk permission pattern: 2. `**Use `--confirm` for all generation/delete commands** to avoid blocking prom`

```
1043 |  
1044 | 1. **Always run `nlm login` first** if any auth error occurs  
> 1045 | 2. **Use `--confirm` for all generation/delete commands** to avoid blocking prompts  
1046 | 3. **Capture IDs from create outputs** - you'll need them for subsequent operations  
1047 | 4. **Use aliases** for frequently-used notebooks to simplify commands
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#33 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/ai_docs.py:1052](#)

High-risk permission pattern: 9. `**& p ALWAYS ask user before delete** - Before running ANY delete command, ask`

```
1050 | 7. **Re-authenticate only for stale/missing credentials** - `unverified` means the probe was  
inconclusive  
1051 | 8. **Use `--max-wait 0`** for single status poll instead of blocking  
> 1052 | 9. **& p ALWAYS ask user before delete** - Before running ANY delete command, ask the user for explicit  
confirmation. Deletions are IRREVERSIBLE. Show what will be deleted and warn about permanent data loss.  
1053 | 10. **Check aliases before creating** - Run `nlm alias list` or `nlm list aliases` before creating a  
new alias to avoid conflicts with existing names.  
1054 | 11. **DO NOT launch REPL** - Never use `nlm chat start` - it opens an interactive REPL that AI tools  
cannot control. Use `nlm notebook query` or `nlm query notebook` for one-shot Q&A instead.
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#34 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/ai_docs.py:1056](#)

High-risk permission pattern: 13. **Verb-first vs Noun-first**** - Both command styles work identically. Use whi**

```
1054 | 11. **DO NOT launch REPL** - Never use `nlm chat start` - it opens an interactive REPL that AI tools
cannot control. Use `nlm notebook query` or `nlm query notebook` for one-shot Q&A instead.
1055 | 12. **Choose output format wisely** - Default output (no flags) is compact and token-efficient—use
it for status checks. Use `--quiet` to capture IDs for piping. Only use `--json` when you need to parse
specific fields programmatically.
> 1056 | 13. **Verb-first vs Noun-first** - Both command styles work identically. Use whichever is more
natural for the context. Noun-first groups by resource (notebook, source), verb-first groups by action
(create, list, delete).
1057 | 14. **Download workflow** - Always wait for artifact completion before downloading. Check status
with `nlm studio status <notebook>`, get the artifact ID, then download with `nlm download <type> <notebook>`
--id <artifact-id>.
1058 | 15. **Artifact generation takes time** - Audio/video: 1-5 minutes. Reports/quizzes: 30-60 seconds.
Always poll status before attempting download.
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#35 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/ai_docs.py:358](#)

Unrestricted agent autonomy: - `--confirm` or `-y`: Skip confirmation (REQUIRED for automation)

```
356 |
357 | **All generation commands support:**
> 358 | - `--confirm` or `-y`: Skip confirmation (REQUIRED for automation)
359 | - `--source-ids <id1,id2>`: Limit to specific sources
360 | - `--language <code>`: BCP-47 code, including regional locales such as `es-419`
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: npm install mcp-secure

#36 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/cli/ai_docs.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """AI-friendly documentation output for the --ai flag."""
2 |
3 | from notebooklm_tools import __version__
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#37 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/cli/commands/__init__.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """CLI command implementations."""...
    2 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#38 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/alias.py:89](#)

High-risk permission pattern: @app.command("delete")

```
87 |
88 |
> 89 | @app.command("delete")
    90 | def delete_alias(
    91 |     name: str = typer.Argument(..., help="Alias name"),
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#39 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/alias.py:94](#)

High-risk permission pattern: """Delete an alias."""

```
92 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation"),
93 | ) -> None:
> 94 |     """Delete an alias."""
    95 |     if not confirm:
    96 |         typer.confirm(f"Are you sure you want to delete alias '{name}'?", abort=True)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#40 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/alias.py:96](#)

High-risk permission pattern: typer.confirm(f"Are you sure you want to delete alias '{name}'?", abort=True)

```
94 |     """Delete an alias."""
95 |     if not confirm:
> 96 |         typer.confirm(f"Are you sure you want to delete alias '{name}'?", abort=True)
    97 |
    98 |     manager = get_alias_manager()
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#41 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/alias.py:92](#)

Unrestricted agent autonomy: confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation")

```
90 | def delete_alias(  
91 |     name: str = typer.Argument(..., help="Alias name"),  
> 92 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation"),  
93 | ) -> None: ...  
94 |     """Delete an alias."""
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: npm install mcp-secure

#42 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/cli/commands/alias.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Alias CLI commands."""  
2 |  
3 | import typer
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#43 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/batch.py:111](#)

High-risk permission pattern: @app.command("delete")

```
109 |  
110 |  
> 111 | @app.command("delete")  
112 | def batch_delete(  
113 |     notebooks: str | None = typer.Option(  
114 |         None,  
115 |         help="Notebooks to delete, separated by commas",  
116 |         metavar="NOTEBOOKS",
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#44 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/batch.py:119](#)

High-risk permission pattern: """Delete multiple notebooks. IRREVERSIBLE."""

```
117 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Confirm deletion"),  
118 | ) -> None:  
> 119 |     """Delete multiple notebooks. IRREVERSIBLE."""  
120 |     from notebooklm_tools.cli.utils import get_client  
121 |     from notebooklm_tools.services import batch as batch_service
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#45 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/batch.py:124](#)

High-risk permission pattern: `typer.confirm("This will PERMANENTLY delete multiple notebooks. Continue?", abort`

```
122 |  
123 |     if not confirm:  
> 124 |         typer.confirm("This will PERMANENTLY delete multiple notebooks. Continue?", abort=True)  
125 |         confirm = True...  
126 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#46 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/cli/commands/batch.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Batch CLI commands – perform operations across multiple notebooks."""  
2 |  
3 | import typer
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#47 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/cli/commands/chat.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Chat configuration CLI commands."""  
2 |  
3 | import typer
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#48 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/cli/commands/chats.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """CLI commands for notebook chat sessions (nlm chats / nlm chat)."""
  2 | ...
  3 | import typer
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#49 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/cli/commands/config.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Configuration CLI commands."""
  2 |
  3 | import typer
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#50 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/cli/commands/cross.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Cross-notebook CLI commands – query across multiple notebooks."""
  2 |
  3 | import typer
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#51 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/notebooklm_tools/cli/commands/doctor.py:386](#)

Dangerous execution: result = subprocess.run(# nosec B603 — cmd from shutil.which(), args are hardc

```
384 |         if claude_cmd:
385 |             try:
> 386 |                 result = subprocess.run( # nosec B603 — cmd from shutil.which(), args are
    |                 hardcoded strings, no shell=True
387 |                 [claude_cmd, "mcp", "list"],
388 |                 capture_output=True,
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#52 AS-006 -- SANDBOXING

HIGH

OWASP: AA-09 | MITRE: T1610 | STRIDE: Elevation of Privilege

Code execution without sandboxing or isolation mechanisms

[src/notebooklm_tools/cli/commands/doctor.py:386](#)

Code execution without sandboxing

```
384 |             if claude_cmd:
385 |                 try:
> 386 |                     result = subprocess.run( # nsec B603 - cmd from shutil.which(), args are
hardcoded strings, no shell=True
387 |                         [claude_cmd, "mcp", "list"],...
388 |                         capture_output=True,
```

Remediation:

1. Run all agent-generated code in Docker containers with --network=none and read-only filesystem. 2. Use gVisor/Firecracker for stronger isolation. 3. Set resource limits (CPU, memory, time) on execution. 4. Use E2B or Modal for managed sandboxed execution. 5. Never execute agent code in the host process.

MCPS Quick Fix: `npm install mcp-secure`

#53 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/cli/commands/doctor.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Diagnostic command for troubleshooting Gemini Notebook MCP setup."""
2 |
3 | import platform
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#54 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/cli/commands/download.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Download CLI commands."""
2 |
3 | import asyncio
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#55 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/cli/commands/export.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Export CLI commands - Export artifacts to Google Docs/Sheets."""
2 |
3 | import typer
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#56 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/label.py:235](#)

High-risk permission pattern: `@app.command("delete")`

```
233 |  
234 |  
> 235 | @app.command("delete")  
236 |     def delete_label(...  
237 |         notebook_id: str = typer.Argument(..., help="Notebook ID or alias"),
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#57 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/label.py:238](#)

High-risk permission pattern: `label_id: str = typer.Argument(..., help="Label UUID to delete")`,

```
236 | def delete_label(  
237 |     notebook_id: str = typer.Argument(..., help="Notebook ID or alias"),  
> 238 |     label_id: str = typer.Argument(..., help="Label UUID to delete"),  
239 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Confirm deletion without prompt"),  
240 |     json_output: bool = typer.Option(False, "--json", "-j", help="Output as JSON"),
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#58 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/label.py:243](#)

High-risk permission pattern: `"""Delete a label permanently. Sources are NOT deleted."""`

```
241 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),  
242 | ) -> None:  
> 243 |     """Delete a label permanently. Sources are NOT deleted."""  
244 |     if not confirm:  
245 |         confirmed = typer.confirm(
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#59 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/label.py:246](#)

High-risk permission pattern: "Delete label {label_id[:8]}...? Sources will be preserved.",

```
244 |         if not confirm:
245 |             confirmed = typer.confirm(
> 246 |                 f"Delete label {label_id[:8]}...? Sources will be preserved.",
247 |                 default=False, ...
248 |             )
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#60 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/label.py:102](#)

Unrestricted agent autonomy: False, "--confirm", "-y", help="Skip confirmation prompt (all-sources mode)"

```
100 |         ),
101 |         confirm: bool = typer.Option(
> 102 |             False, "--confirm", "-y", help="Skip confirmation prompt (all-sources mode)"
103 |         ),
104 |         json_output: bool = typer.Option(False, "--json", "-j", help="Output as JSON"),
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: `npm install mcp-secure`

#61 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/cli/commands/label.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Label CLI commands - manage source labels in a notebook."""
2 |
3 | import typer
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#62 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/note.py:105](#)

High-risk permission pattern: @app.command("delete")

```
103 |
104 |
> 105 | @app.command("delete")
106 | def delete_note(
107 |     notebook_id: str = typer.Argument(..., help="Notebook ID"),
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#63 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/note.py:108](#)

High-risk permission pattern: `note_id: str = typer.Argument(..., help="Note ID to delete")`,

```
106 | def delete_note(  
107 |     notebook_id: str = typer.Argument(..., help="Notebook ID"),  
> 108 |     note_id: str = typer.Argument(..., help="Note ID to delete"),  
109 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation"),...  
110 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#64 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/note.py:112](#)

High-risk permission pattern: `"""Delete a note permanently."""`

```
110 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),  
111 | ) -> None:  
> 112 |     """Delete a note permanently."""  
113 |     if not confirm:  
114 |         confirmed = typer.confirm(f"Delete note {note_id}? This action is IRREVERSIBLE.")
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#65 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/note.py:114](#)

High-risk permission pattern: `confirmed = typer.confirm(f"Delete note {note_id}? This action is IRREVERSIBLE.")`

```
112 |     """Delete a note permanently."""  
113 |     if not confirm:  
> 114 |         confirmed = typer.confirm(f"Delete note {note_id}? This action is IRREVERSIBLE.")  
115 |         if not confirmed:  
116 |             console.print("[dim]Cancelled[/dim]")
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#66 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/note.py:109](#)

Unrestricted agent autonomy: confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation")

```
107 |     notebook_id: str = typer.Argument(..., help="Notebook ID"),
108 |     note_id: str = typer.Argument(..., help="Note ID to delete"),
> 109 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation"),
110 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),...
111 | ) -> None:
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: npm install mcp-secure

#67 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/cli/commands/note.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Note CLI commands."""
  2 |
  3 | import typer
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#68 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/notebook.py:120](#)

High-risk permission pattern: @app.command("delete")

```
118 |
119 |
> 120 | @app.command("delete")
121 | def delete_notebook(
122 |     notebook_id: str = typer.Argument(..., help="Notebook ID"),
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#69 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/notebook.py:127](#)

High-risk permission pattern: """Delete a notebook permanently."""

```
125 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
126 | ) -> None:
> 127 |     """Delete a notebook permanently."""
128 |     notebook_id = get_alias_manager().resolve(notebook_id)
129 |
```


Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#70 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/notebook.py:132](#)

High-risk permission pattern: `f"Are you sure you want to delete notebook {notebook_id}?"`,

```
130 |         if not confirm:
131 |             typer.confirm(
> 132 |                 f"Are you sure you want to delete notebook {notebook_id}?",
133 |                 abort=True,...
134 |             )
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#71 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/notebook.py:123](#)

Unrestricted agent autonomy: `confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation")`

```
121 | def delete_notebook(
122 |     notebook_id: str = typer.Argument(..., help="Notebook ID"),
> 123 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation"),
124 |     json_output: bool = typer.Option(False, "--json", "-j", help="Output as JSON"),
125 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use `tool_choice='none'` or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: `npm install mcp-secure`

#72 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/cli/commands/notebook.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Notebook CLI commands."""
  2 |
  3 | import typer
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include `agent_id`, `timestamp`, `action`, `parameters`, and `outcome` in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#73 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/pipeline.py:1](#)

High-risk permission pattern: """Pipeline CLI commands — define and execute multi-step workflows."""

```
> 1 | """Pipeline CLI commands — define and execute multi-step workflows."""
    2 | ...
    3 | import typer
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#74 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/pipeline.py:24](#)

High-risk permission pattern: """Execute a pipeline on a notebook."""

```
22 |     input_url: str = typer.Option("", "--input-url", "-u", help="URL variable ($INPUT_URL)",
23 | ) -> None:
> 24 |     """Execute a pipeline on a notebook."""
    25 |     from notebooklm_tools.cli.utils import get_client
    26 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#75 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/cli/commands/pipeline.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Pipeline CLI commands — define and execute multi-step workflows."""
    2 |
    3 | import typer
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#76 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/cli/commands/repl.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Interactive REPL for notebook chat."""
    2 |
    3 | import contextlib
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#77 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/cli/commands/research.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Research CLI commands."""
  2 | ...
  3 | import typer
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#78 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/setup.py:1593](#)

High-risk permission pattern: # Execute setup for selected tools

```
1591 |         return
1592 |
> 1593 |         # Execute setup for selected tools
1594 |         console.print()
1595 |         setup_fns = {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#79 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/setup.py:2131](#)

High-risk permission pattern: # Execute removal

```
2129 |         return
2130 |
> 2131 |         # Execute removal
2132 |         console.print()
2133 |         removed_count = 0
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#80 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/setup_wizard.py:242](#)

High-risk permission pattern: """Execute Add MCP setup for all selected tools, isolating failures."""

```
240 |
241 | def run_add(selected: list[str]) -> list[SetupResult]:
> 242 |     """Execute Add MCP setup for all selected tools, isolating failures."""
243 |     results: list[SetupResult] = []
244 |     targets = {target.id: target for target in scan_mcp_targets()}
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#81 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/setup_wizard.py:951](#)

High-risk permission pattern: "Delete the listed skill folders? Personal edits in the active folders will be r

```
949 |         allowed = ask_with_back(  
950 |             questionnaire.confirm(  
> 951 |                 "Delete the listed skill folders? Personal edits in the active folders will be  
removed.",  
952 |                 default=False,  
953 |                 style=WIZARD_STYLE,
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#82 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/cli/commands/setup_wizard.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Interactive setup wizard for adding and removing Gemini Notebook MCP and skills."""  
2 |  
3 | import platform
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#83 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/cli/commands/share.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Sharing CLI commands."""  
2 |  
3 | import typer
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#84 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/source.py:329](#)

High-risk permission pattern: `@app.command("delete")`

```
327 |  
328 |  
> 329 | @app.command("delete")  
330 |     def delete_source(...  
331 |         source_ids: list[str] = typer.Argument(..., help="Source ID(s) to delete"), # noqa: B008
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#85 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/source.py:331](#)

High-risk permission pattern: `source_ids: list[str] = typer.Argument(..., help="Source ID(s) to delete"), # n`

```
329 | @app.command("delete")  
330 | def delete_source(  
> 331 |     source_ids: list[str] = typer.Argument(..., help="Source ID(s) to delete"), # noqa: B008  
332 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation"),  
333 |     json_output: bool = typer.Option(False, "--json", "-j", help="Output as JSON"),
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#86 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/source.py:336](#)

High-risk permission pattern: `"""Delete source(s) permanently.`

```
334 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),  
335 | ) -> None:  
> 336 |     """Delete source(s) permanently.  
337 |  
338 |     Accepts one or more source IDs for single or bulk deletion.
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#87 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/source.py:341](#)

High-risk permission pattern: `nlm source delete <source-id> --confirm`

```
339 |  
340 |     Examples:  
> 341 |         nlm source delete <source-id> --confirm  
342 |         nlm source delete <id1> <id2> <id3> --confirm  
343 |         """
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#88 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/source.py:342](#)

High-risk permission pattern: `nlm source delete <id1> <id2> <id3> --confirm`

```
340 |     Examples:
341 |         nlm source delete <source-id> --confirm
> 342 |         nlm source delete <id1> <id2> <id3> --confirm
343 |         """...
344 |         resolved_ids = [get_alias_manager().resolve(sid) for sid in source_ids]
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#89 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/source.py:349](#)

High-risk permission pattern: `f"Are you sure you want to delete source {resolved_ids[0]}?"`,

```
347 |         if len(resolved_ids) == 1:
348 |             typer.confirm(
> 349 |                 f"Are you sure you want to delete source {resolved_ids[0]}?",
350 |                 abort=True,
351 |             )
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#90 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/source.py:354](#)

High-risk permission pattern: `f"Are you sure you want to delete {len(resolved_ids)} sources?"`,

```
352 |         else:
353 |             typer.confirm(
> 354 |                 f"Are you sure you want to delete {len(resolved_ids)} sources?",
355 |                 abort=True,
356 |             )
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#91 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/source.py:332](#)

Unrestricted agent autonomy: confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation")

```
330 | def delete_source(  
331 |     source_ids: list[str] = typer.Argument(..., help="Source ID(s) to delete"), # noqa: B008  
> 332 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation"),  
333 |     json_output: bool = typer.Option(False, "--json", "-j", help="Output as JSON"),...  
334 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: `npm install mcp-secure`

#92 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/source.py:418](#)

Unrestricted agent autonomy: confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation")

```
416 |         help="Comma-separated source IDs to sync (default: all stale)",  
417 |     ),  
> 418 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation"),  
419 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),  
420 | ) -> None:
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: `npm install mcp-secure`

#93 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/cli/commands/source.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Source CLI commands."""  
2 |  
3 | import typer
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#94 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/studio.py:21](#)

High-risk permission pattern: # Main studio app for status/delete

```
19 | console = make_console()
20 |
> 21 | # Main studio app for status/delete
    22 | app = typer.Typer(...)
    23 |     help="Manage studio artifacts",
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#95 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/studio.py:145](#)

High-risk permission pattern: # ===== Studio Status/Delete =====

```
143 |
144 |
> 145 | # ===== Studio Status/Delete =====
    146 |
    147 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#96 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/studio.py:211](#)

High-risk permission pattern: @app.command("delete")

```
209 |
210 |
> 211 | @app.command("delete")
    212 | def studio_delete(
    213 |     notebook_id: str = typer.Argument(..., help="Notebook ID"),
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#97 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/studio.py:214](#)

High-risk permission pattern: artifact_id: str = typer.Argument(..., help="Artifact ID to delete"),

```
212 | def studio_delete(
213 |     notebook_id: str = typer.Argument(..., help="Notebook ID"),
> 214 |     artifact_id: str = typer.Argument(..., help="Artifact ID to delete"),
    215 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation"),
    216 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
```


Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#98 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/studio.py:218](#)

High-risk permission pattern: `""Delete a studio artifact permanently.""`

```
216 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
217 | ) -> None:
218 |     ""Delete a studio artifact permanently.""
219 |     notebook_id = get_alias_manager().resolve(notebook_id)...
220 |     artifact_id = get_alias_manager().resolve(artifact_id)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#99 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/studio.py:223](#)

High-risk permission pattern: `typer.confirm(f"Are you sure you want to delete artifact {artifact_id}?", abort=`

```
221 |
222 |     if not confirm:
223 |         typer.confirm(f"Are you sure you want to delete artifact {artifact_id}?", abort=True)
224 |
225 |     try:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#100 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/studio.py:215](#)

Unrestricted agent autonomy: `confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation")`

```
213 |     notebook_id: str = typer.Argument(..., help="Notebook ID"),
214 |     artifact_id: str = typer.Argument(..., help="Artifact ID to delete"),
215 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation"),
216 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
217 | ) -> None:
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use `tool_choice='none'` or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: `npm install mcp-secure`

#101 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/studio.py:286](#)

Unrestricted agent autonomy: confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation")

```
284 |         help="Comma-separated source IDs",
285 |     ),
> 286 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation"),
287 |     json_output: bool = typer.Option(False, "--json", "-j", help="Output as JSON"),...
288 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: `npm install mcp-secure`

#102 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/studio.py:335](#)

Unrestricted agent autonomy: confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation")

```
333 |         None, "--source-ids", "-s", help="Comma-separated source IDs"
334 |     ),
> 335 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation"),
336 |     json_output: bool = typer.Option(False, "--json", "-j", help="Output as JSON"),
337 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: `npm install mcp-secure`

#103 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/studio.py:520](#)

Unrestricted agent autonomy: confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation")

```
518 |         help="Element setting name=value (repeatable); see 'nlm report elements --json'",
519 |     ),
> 520 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation"),
521 |     json_output: bool = typer.Option(False, "--json", "-j", help="Output as JSON"),
522 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: `npm install mcp-secure`

#104 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/studio.py:578](#)

Unrestricted agent autonomy: confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation")

```
576 |         "", "--language", help="BCP-47 code (default: the report's language)"
577 |     ),
> 578 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation"),
579 |     json_output: bool = typer.Option(False, "--json", "-j", help="Output as JSON"),...
580 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: `npm install mcp-secure`

#105 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/studio.py:646](#)

Unrestricted agent autonomy: confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation")

```
644 |         None, "--source-ids", "-s", help="Comma-separated source IDs"
645 |     ),
> 646 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation"),
647 |     json_output: bool = typer.Option(False, "--json", "-j", help="Output as JSON"),
648 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: `npm install mcp-secure`

#106 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/studio.py:726](#)

Unrestricted agent autonomy: confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation")

```
724 |         None, "--source-ids", "-s", help="Comma-separated source IDs"
725 |     ),
> 726 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation"),
727 |     json_output: bool = typer.Option(False, "--json", "-j", help="Output as JSON"),
728 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: `npm install mcp-secure`

#107 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/studio.py:756](#)

Unrestricted agent autonomy: confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation")

```
754 |         None, "--source-ids", "-s", help="Comma-separated source IDs"
755 |     ),
> 756 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation"),
757 |     json_output: bool = typer.Option(False, "--json", "-j", help="Output as JSON"),...
758 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: `npm install mcp-secure`

#108 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/studio.py:795](#)

Unrestricted agent autonomy: confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation")

```
793 |         None, "--source-ids", "-s", help="Comma-separated source IDs"
794 |     ),
> 795 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation"),
796 |     json_output: bool = typer.Option(False, "--json", "-j", help="Output as JSON"),
797 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: `npm install mcp-secure`

#109 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/studio.py:825](#)

Unrestricted agent autonomy: confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation")

```
823 |         help='Slide revision in format: SLIDE_NUM "instruction" (e.g., --slide 1 "Make title
larger")',
824 |     ),
> 825 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation"),
826 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
827 | ) -> None:
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: `npm install mcp-secure`

#110 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/studio.py:911](#)

Unrestricted agent autonomy: confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation")

```
909 |         None, "--source-ids", "-s", help="Comma-separated source IDs"
910 |     ),
> 911 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation"),
912 |     json_output: bool = typer.Option(False, "--json", "-j", help="Output as JSON"),...
913 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: npm install mcp-secure

#111 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/studio.py:965](#)

Unrestricted agent autonomy: confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation")

```
963 |     ),
964 |     source_ids: str | None = typer.Option(None, "--source-ids", help="Comma-separated source IDs"),
> 965 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation"),
966 |     json_output: bool = typer.Option(False, "--json", "-j", help="Output as JSON"),
967 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: npm install mcp-secure

#112 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/studio.py:1022](#)

Unrestricted agent autonomy: confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation")

```
1020 |         None, "--source-ids", "-s", help="Comma-separated source IDs"
1021 |     ),
> 1022 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation"),
1023 |     json_output: bool = typer.Option(False, "--json", "-j", help="Output as JSON"),
1024 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: npm install mcp-secure

#113 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/cli/commands/studio.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Studio CLI commands for generation (audio, report, quiz, etc.)."""
  2 | ...
  3 | import json
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#114 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/cli/commands/tag.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tag CLI commands - manage notebook tags for smart selection."""
  2 |
  3 | import typer
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#115 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/cli/commands/usage.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Show how much of the plan's usage allowance is left."""
  2 |
  3 | import json as json_lib
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#116 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/verbs.py:6](#)

High-risk permission pattern: - nlm delete notebook <id> (vs nlm notebook delete <id>)

```
> 4 | - nlm create notebook "Title" (vs nlm notebook create "Title")
  5 | - nlm list notebooks (vs nlm notebook list)
  6 | - nlm delete notebook <id> (vs nlm notebook delete <id>)
  7 |
  8 | Both command structures coexist for user flexibility.
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#117 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/verbs.py:526](#)

High-risk permission pattern: # DELETE verb

```
524 |  
525 | # =====  
> 526 | # DELETE verb  
527 | # =====  
528 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#118 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/verbs.py:529](#)

High-risk permission pattern: `delete_app = typer.Typer(help="Delete resources (notebooks, sources, artifacts)")`

```
527 | # =====  
528 |  
> 529 | delete_app = typer.Typer(help="Delete resources (notebooks, sources, artifacts)")  
530 |  
531 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#119 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/verbs.py:539](#)

High-risk permission pattern: `"""Delete a notebook permanently."""`

```
537 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),  
538 | ) -> None:  
> 539 |     """Delete a notebook permanently."""  
540 |     delete_notebook(  
541 |         notebook_id=notebook,
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#120 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/verbs.py:555](#)

High-risk permission pattern: `"""Delete a source from notebook."""`

```
553 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),  
554 | ) -> None:  
> 555 |     """Delete a source from notebook."""  
556 |     delete_source(  
557 |         source_ids=[source],
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#121 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/verbs.py:571](#)

High-risk permission pattern: `""Delete a studio artifact permanently."""`

```
569 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
570 | ) -> None:
571 |     """Delete a studio artifact permanently."""
572 |     studio_delete(notebook_id=notebook, artifact_id=artifact, confirm=confirm, profile=profile)...
573 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#122 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/verbs.py:580](#)

High-risk permission pattern: `""Delete an alias."""`

```
578 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation prompt"),
579 | ) -> None:
580 |     """Delete an alias."""
581 |     delete_alias(name=name, confirm=confirm)
582 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#123 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/verbs.py:128](#)

Unrestricted agent autonomy: `confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation p`

```
126 |         None, "--source-ids", "-s", help="Comma-separated source IDs"
127 |     ),
> 128 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation prompt"),
129 |     json_output: bool = typer.Option(False, "--json", "-j", help="Output as JSON"),
130 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use `tool_choice='none'` or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: `npm install mcp-secure`

#124 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/verbs.py:166](#)

Unrestricted agent autonomy: confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation p

```
164 |         focus: str | None = typer.Option(None, "--focus", help="Optional focus topic"),
165 |         source_ids: str | None = typer.Option(None, "--source-ids", help="Comma-separated source IDs"),
> 166 |         confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation prompt"),
167 |         json_output: bool = typer.Option(False, "--json", "-j", help="Output as JSON"),...
168 |         profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: `npm install mcp-secure`

#125 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/verbs.py:207](#)

Unrestricted agent autonomy: confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation p

```
205 |         None, "--source-ids", "-s", help="Comma-separated source IDs"
206 |     ),
> 207 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation prompt"),
208 |     json_output: bool = typer.Option(False, "--json", "-j", help="Output as JSON"),
209 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: `npm install mcp-secure`

#126 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/verbs.py:244](#)

Unrestricted agent autonomy: confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation p

```
242 |         None, "--source-ids", "-s", help="Comma-separated source IDs"
243 |     ),
> 244 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation prompt"),
245 |     json_output: bool = typer.Option(False, "--json", "-j", help="Output as JSON"),
246 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: `npm install mcp-secure`

#127 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/verbs.py:275](#)

Unrestricted agent autonomy: confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation p

```
273 |         None, "--source-ids", "-s", help="Comma-separated source IDs"
274 |     ),
> 275 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation prompt"),
276 |     json_output: bool = typer.Option(False, "--json", "-j", help="Output as JSON"),...
277 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: `npm install mcp-secure`

#128 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/verbs.py:304](#)

Unrestricted agent autonomy: confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation p

```
302 |         None, "--source-ids", "-s", help="Comma-separated source IDs"
303 |     ),
> 304 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation prompt"),
305 |     json_output: bool = typer.Option(False, "--json", "-j", help="Output as JSON"),
306 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: `npm install mcp-secure`

#129 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/verbs.py:331](#)

Unrestricted agent autonomy: confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation p

```
329 |         None, "--source-ids", "-s", help="Comma-separated source IDs"
330 |     ),
> 331 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation prompt"),
332 |     json_output: bool = typer.Option(False, "--json", "-j", help="Output as JSON"),
333 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: `npm install mcp-secure`

#130 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/verbs.py:355](#)

Unrestricted agent autonomy: confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation p

```
353 |         None, "--source-ids", "-s", help="Comma-separated source IDs"
354 |     ),
> 355 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation prompt"),
356 |     json_output: bool = typer.Option(False, "--json", "-j", help="Output as JSON"),...
357 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: npm install mcp-secure

#131 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/verbs.py:378](#)

Unrestricted agent autonomy: confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation p

```
376 |         None, "--source-ids", "-s", help="Comma-separated source IDs"
377 |     ),
> 378 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation prompt"),
379 |     json_output: bool = typer.Option(False, "--json", "-j", help="Output as JSON"),
380 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: npm install mcp-secure

#132 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/verbs.py:535](#)

Unrestricted agent autonomy: confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation p

```
533 | def delete_notebook_verb(
534 |     notebook: str = typer.Argument(..., help="Notebook ID or alias"),
> 535 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation prompt"),
536 |     json_output: bool = typer.Option(False, "--json", "-j", help="Output as JSON"),
537 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: npm install mcp-secure

#133 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/verbs.py:551](#)

Unrestricted agent autonomy: confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation p

```
549 | def delete_source_verb(  
550 |     source: str = typer.Argument(..., help="Source ID"),  
> 551 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation prompt"),  
552 |     json_output: bool = typer.Option(False, "--json", "-j", help="Output as JSON"),...  
553 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: `npm install mcp-secure`

#134 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/verbs.py:568](#)

Unrestricted agent autonomy: confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation p

```
566 |     notebook: str = typer.Argument(..., help="Notebook ID or alias"),  
567 |     artifact: str = typer.Argument(..., help="Artifact ID"),  
> 568 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation prompt"),  
569 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),  
570 | ) -> None:
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: `npm install mcp-secure`

#135 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/verbs.py:578](#)

Unrestricted agent autonomy: confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation p

```
576 | def delete_alias_verb(  
577 |     name: str = typer.Argument(..., help="Alias name"),  
> 578 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation prompt"),  
579 | ) -> None:  
580 |     """Delete an alias."""
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: `npm install mcp-secure`

#136 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/verbs.py:848](#)

Unrestricted agent autonomy: confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation")

```
846 |         None, "--source-ids", "-s", help="Comma-separated source IDs to sync (default: all stale)"
847 |     ),
> 848 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation"),
849 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),...
850 | ) -> None:
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use `tool_choice='none'` or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: npm install mcp-secure

#137 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/cli/commands/verbs.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Verb-first CLI commands for NotebookLM Tools.
2 |
3 | This module provides alternative command structure:
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include `agent_id`, `timestamp`, `action`, `parameters`, and `outcome` in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#138 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/cli/formatters.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Output formatting utilities for NLM CLI."""
2 |
3 | from __future__ import annotations
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include `agent_id`, `timestamp`, `action`, `parameters`, and `outcome` in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#139 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/main.py:245](#)

High-risk permission pattern: help="Delete the localized browser profile data before logging in, to switch Google

```
243 |         False,
244 |         "--clear",
> 245 |         help="Delete the localized browser profile data before logging in, to switch Google
accounts",
246 |     ),
247 |     wsl: bool = typer.Option(
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#140 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/main.py:694](#)

High-risk permission pattern: `@profile_app.command("delete")`

```
692 |  
693 |  
> 694 | @profile_app.command("delete")  
695 | def profile_delete(...  
696 |     profile: str = typer.Argument(..., help="Profile name to delete"),
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#141 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/main.py:696](#)

High-risk permission pattern: `profile: str = typer.Argument(..., help="Profile name to delete"),`

```
694 | @profile_app.command("delete")  
695 | def profile_delete(  
> 696 |     profile: str = typer.Argument(..., help="Profile name to delete"),  
697 |     confirm: bool = typer.Option(  
698 |         False,
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#142 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/main.py:704](#)

High-risk permission pattern: `"""Delete a profile and its credentials."""`

```
702 |     ),  
703 | ) -> None:  
> 704 |     """Delete a profile and its credentials."""  
705 |     from notebooklm_tools.services.auth import AuthManager  
706 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#143 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/main.py:716](#)

High-risk permission pattern: `f"Are you sure you want to delete profile '{profile}'?"`,

```
714 |         if not confirm:
715 |             typer.confirm(
> 716 |                 f"Are you sure you want to delete profile '{profile}'?",
717 |                 abort=True,...
718 |             )
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#144 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/main.py:759](#)

High-risk permission pattern: `# Delete old profile`

```
757 |         )
758 |
> 759 |         # Delete old profile
760 |         old_auth.delete_profile()
761 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#145 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/main.py:912](#)

High-risk permission pattern: `app.add typer(delete_app, name="delete", help="Delete resources (notebooks, sour`

```
910 | app.add typer(list_app, name="list", help="List resources (notebooks, sources, artifacts)")
911 | app.add typer(get_app, name="get", help="Get details about resources")
> 912 | app.add typer(delete_app, name="delete", help="Delete resources (notebooks, sources, artifacts)")
913 | app.add typer(add_app, name="add", help="Add resources (sources to notebooks)")
914 | app.add typer(rename_app, name="rename", help="Rename resources")
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#146 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/main.py:701](#)

Unrestricted agent autonomy: `help="Skip confirmation prompt"`,

```
699 |         "--confirm",
700 |         "-y",
> 701 |         help="Skip confirmation prompt",
702 |     ),
703 | ) -> None:
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use `tool_choice='none'` or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: [npm install mcp-secure](#)

#147 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/cli/setup_safety.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Safe configuration file reading, atomic writing, and backup primitives."""
  2 | ...
  3 | import json
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include `agent_id`, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#148 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/cli/skill_package.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Package the Gemini Notebook skill as a zip for Claude's skill upload.
  2 |
  3 | Claude Desktop (Chat, Cowork) and claude.ai load skills uploaded to the user's
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include `agent_id`, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#149 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

[src/notebooklm_tools/cli/utils.py:149](#)

File input near prompt/instruction handling — injection vector

```
147 |
148 |     try:
> 149 |         with open(cache_path, encoding="utf-8") as f:
150 |             data = json.load(f)
151 |
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#150 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

[src/notebooklm_tools/cli/utils.py:167](#)

File input near prompt/instruction handling — injection vector

```
165 |         return
166 |     try:
> 167 |         with open(cache_path, "w", encoding="utf-8") as f:
168 |             json.dump(...)
169 |                 {
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#151 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

[src/notebooklm_tools/cli/utils.py:184](#)

File input near prompt/instruction handling — injection vector

```
182 |         url = "https://pypi.org/pypi/notebooklm-mcp-cli/json"
183 |         req = urllib.request.Request(url, headers={"User-Agent": "notebooklm-mcp-cli"})
> 184 |         with urllib.request.urlopen(req, timeout=2) as response: # nsec B310 – URL is hardcoded to
https://pypi.org
185 |             data = json.loads(response.read().decode())
186 |             return data.get("info", {}).get("version")
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#152 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/cli/utils.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | import json
2 | import os
3 | import shutil
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#153 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/cli/utils.py:6](#)

Dynamic HTTP with sensitive data context

```
4 | import sys
5 | import time
> 6 | import urllib.request
7 | from pathlib import Path
8 |
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#154 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/cli/utils.py:183](#)

Dynamic HTTP with sensitive data context

```
181 |         try:
182 |             url = "https://pypi.org/pypi/notebooklm-mcp-cli/json"
> 183 |             req = urllib.request.Request(url, headers={"User-Agent": "notebooklm-mcp-cli"})
184 |             with urllib.request.urlopen(req, timeout=2) as response: # nosec B310 – URL is hardcoded to
https://pypi.org...
185 |                 data = json.loads(response.read()).decode()
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#155 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/cli/utils.py:184](#)

Dynamic HTTP with sensitive data context

```
182 |         url = "https://pypi.org/pypi/notebooklm-mcp-cli/json"
183 |         req = urllib.request.Request(url, headers={"User-Agent": "notebooklm-mcp-cli"})
> 184 |         with urllib.request.urlopen(req, timeout=2) as response: # nosec B310 – URL is hardcoded to
https://pypi.org
185 |             data = json.loads(response.read()).decode()
186 |             return data.get("info", {}).get("version")
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#156 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/core/__init__.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Core functionality shared between CLI and MCP interfaces."""
2 |
3 | from notebooklm_tools.core import constants
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#157 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/alias.py:77](#)

High-risk permission pattern: """Delete an alias. Returns True if deleted."""

```
75 |  
76 |     def delete_alias(self, name: str) -> bool:  
> 77 |         """Delete an alias. Returns True if deleted."""  
78 |         if name in self._aliases:  
79 |             del self._aliases[name]
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#158 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/core/alias.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Alias management for NotebookLM CLI."""  
2 |  
3 | import json
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#159 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/auth.py:556](#)

High-risk permission pattern: """Delete the current profile."""

```
554 |  
555 |     def delete_profile(self) -> None:  
> 556 |         """Delete the current profile."""  
557 |         import shutil  
558 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#160 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

[src/notebooklm_tools/core/auth.py:133](#)

File input near prompt/instruction handling — injection vector

```
131 |  
132 |     try:  
> 133 |         with open(cache_path, encoding="utf-8") as f:  
134 |             data = json.load(f)  
135 |             tokens = AuthTokens.from_dict(data)
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#161 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

[src/notebooklm_tools/core/auth.py:177](#)

File input near prompt/instruction handling — injection vector

```
175 |         cache_path.parent.chmod(stat.S_IRWXU) # 0o700
> 176 |         # TOCTOU-safe: create the file with 0o600 from the start (PR #205)
177 |         fd = os.open(str(cache_path), os.O_WRONLY | os.O_CREAT | os.O_TRUNC, 0o600)
178 |         try:
179 |             f = os.fdopen(fd, "w", encoding="utf-8")
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#162 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

[src/notebooklm_tools/core/auth.py:179](#)

File input near prompt/instruction handling — injection vector

```
177 |         fd = os.open(str(cache_path), os.O_WRONLY | os.O_CREAT | os.O_TRUNC, 0o600)
> 178 |         try:
179 |             f = os.fdopen(fd, "w", encoding="utf-8")
180 |         except BaseException:
181 |             os.close(fd)
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#163 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

[src/notebooklm_tools/core/auth.py:505](#)

File input near prompt/instruction handling — injection vector

```
503 |
504 |         # Save cookies with restrictive permissions from creation
> 505 |         fd = os.open(str(self.cookies_file), os.O_WRONLY | os.O_CREAT | os.O_TRUNC, 0o600)
506 |         try:
507 |             f = os.fdopen(fd, "w", encoding="utf-8")
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#164 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

[src/notebooklm_tools/core/auth.py:507](#)

File input near prompt/instruction handling — injection vector

```
505 |         fd = os.open(str(self.cookies_file), os.O_WRONLY | os.O_CREAT | os.O_TRUNC, 0o600)
506 |         try:
> 507 |             f = os.fdopen(fd, "w", encoding="utf-8")
508 |         except BaseException:
509 |             os.close(fd)
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#165 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

[src/notebooklm_tools/core/auth.py:534](#)

File input near prompt/instruction handling — injection vector

```
532 |         "last_validated": datetime.now().isoformat(),
533 |     }
> 534 |     fd = os.open(str(self.metadata_file), os.O_WRONLY | os.O_CREAT | os.O_TRUNC, 0o600)
535 |     try:
536 |         f = os.fdopen(fd, "w", encoding="utf-8")
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#166 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

[src/notebooklm_tools/core/auth.py:536](#)

File input near prompt/instruction handling — injection vector

```
534 |         fd = os.open(str(self.metadata_file), os.O_WRONLY | os.O_CREAT | os.O_TRUNC, 0o600)
535 |         try:
> 536 |             f = os.fdopen(fd, "w", encoding="utf-8")
537 |         except BaseException:
538 |             os.close(fd)
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#167 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/core/auth.py:17](#)

Dynamic HTTP with sensitive data context

```
15 | from pathlib import Path
16 | from typing import Any
> 17 | from urllib.parse import quote
18 |
19 | from notebooklm_tools.utils.config import get_base_url
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#168 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/core/auth.py:618](#)

Dynamic HTTP with sensitive data context

```
616 |         def login_with_file(self, file_path: str | Path) -> Profile:
617 |             """Parse cookies from file and save to profile."""
> 618 |             from urllib.parse import urlparse
619 |             ...
620 |             from notebooklm_tools.core.exceptions import AuthenticationError
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#169 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/base.py:263](#)

High-risk permission pattern: `RPC_DELETE_SOURCE = "tGMBJ"` # Delete a source from notebook

```
261 |         RPC_CHECK_FRESHNESS = "yR9Yof" # Check if Drive source is stale
262 |         RPC_SYNC_DRIVE = "FLmJqe" # Sync Drive source with latest content
> 263 |         RPC_DELETE_SOURCE = "tGMBJ" # Delete a source from notebook
264 |         RPC_RENAME_SOURCE = "b7Wfje" # Rename a source
265 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#170 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/base.py:284](#)

High-risk permission pattern: `RPC_DELETE_STUDIO = "V5N4be"` # Delete Audio or Video Overview

```
282 |         RPC_CREATE_STUDIO = "R7cb6c" # Create Audio or Video Overview
283 |         RPC_POLL_STUDIO = "gArtLc" # Poll for studio content status
> 284 |         RPC_DELETE_STUDIO = "V5N4be" # Delete Audio or Video Overview
285 |         RPC_RENAME_ARTIFACT = "rc3d8d" # Rename any studio artifact (Audio, Video, etc.)
286 |         RPC_GET_INTERACTIVE_HTML = "v9rmvd" # Fetch quiz/flashcard HTML content
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#171 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/base.py:296](#)

High-risk permission pattern: `RPC_DELETE_MIND_MAP = "AH0mwd"` # Delete a mind map

```
294 |     RPC_SAVE_MIND_MAP = "CYK0Xb" # Save generated mind map to notebook
295 |     RPC_LIST_MIND_MAPS = "cFji9" # List existing mind maps
> 296 |     RPC_DELETE_MIND_MAP = "AH0mwd" # Delete a mind map
297 | ...
298 | # Notes RPCs (share RPC IDs with mind maps, differ by parameters)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#172 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/base.py:302](#)

High-risk permission pattern: `RPC_DELETE_NOTE = "AH0mwd"` # Delete note permanently (same as `DELETE_MIND_MAP`)

```
300 |     RPC_GET_NOTES = "cFji9" # List notes and mind maps (same as LIST_MIND_MAPS)
301 |     RPC_UPDATE_NOTE = "cYAfTb" # Update note content/title
> 302 |     RPC_DELETE_NOTE = "AH0mwd" # Delete note permanently (same as DELETE_MIND_MAP)
303 |
304 | # Label RPCs (source organization)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#173 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/base.py:307](#)

High-risk permission pattern: `RPC_LABEL_DELETE = "GyzE7e"` # Delete one or more labels

```
305 |     RPC_LABEL_MANAGE = "agX4Bc" # Auto-label sources / create label / list labels
306 |     RPC_LABEL_MUTATE = "le8sX" # Rename label / set emoji / move source to label
> 307 |     RPC_LABEL_DELETE = "GyzE7e" # Delete one or more labels
308 |
309 | # Sharing RPCs
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#174 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/base.py:933](#)

High-risk permission pattern: `"""Execute a batchexecute RPC through the experimental CDP transport."""`

```
931 |         _server_retry: int = 0,
932 |     ) -> Any:
> 933 |         """Execute a batchexecute RPC through the experimental CDP transport."""
934 |         self._prepare_cdp_transport(timeout if timeout is not None else DEFAULT_TIMEOUT)
935 |         body = self._build_request_body(rpc_id, params)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#175 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/base.py:981](#)

High-risk permission pattern: """Execute an RPC call and return the extracted result.

```
979 |         retry_server_errors: bool = True,
980 |     ) -> Any:
981 |         """Execute an RPC call and return the extracted result.
982 |     ...
983 |         Includes automatic retry on auth failures with three-layer recovery:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#176 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

[src/notebooklm_tools/core/base.py:1302](#)

File input near prompt/instruction handling — injection vector

```
1300 |         # writing first and narrowing after, which leaves a window in
1301 |         # which the file is world-readable.
> 1302 |         fd = os.open(str(debug_path), os.O_WRONLY | os.O_CREAT | os.O_TRUNC, 0o600)
1303 |         try:
1304 |             f = os.fdopen(fd, "w", encoding="utf-8")
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#177 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

[src/notebooklm_tools/core/base.py:1304](#)

File input near prompt/instruction handling — injection vector

```
1302 |         fd = os.open(str(debug_path), os.O_WRONLY | os.O_CREAT | os.O_TRUNC, 0o600)
1303 |         try:
> 1304 |             f = os.fdopen(fd, "w", encoding="utf-8")
1305 |         except BaseException:
1306 |             os.close(fd)
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#178 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/core/base.py:18](#)

Dynamic HTTP with sensitive data context

```
16 | import secrets
17 | import threading
> 18 | import urllib.parse
19 | from collections import OrderedDict...
20 | from typing import Any
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#179 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/core/base.py:694](#)

Dynamic HTTP with sensitive data context

```
692 |
693 |         # URL encode (safe='' encodes all characters including /)
> 694 |         body_parts = [f"f.req={urllib.parse.quote(f_req_json, safe='')}"]
695 |
696 |         if self.csrf_token:
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#180 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/core/base.py:697](#)

Dynamic HTTP with sensitive data context

```
695 |
696 |         if self.csrf_token:
> 697 |             body_parts.append(f"at={urllib.parse.quote(self.csrf_token, safe='')}")
698 |
699 |         # Add trailing & to match NotebookLM's format
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#181 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/core/base.py:716](#)

Dynamic HTTP with sensitive data context

```
714 |         params["f.sid"] = self._session_id
715 |
> 716 |         query = urllib.parse.urlencode(params)
717 |         return f"{self._get_batchexecute_url()}?{query}"
718 |
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#182 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/core/cdp_transport.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Experimental browser-backed RPC transport.
  2 | ...
  3 | This module keeps the CDP implementation small and opt-in. It executes the
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#183 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/client.py:62](#)

High-risk permission pattern: - Notebook management (list, create, rename, delete)

```
60 |
61 |     This class extends BaseClient with all domain-specific operations:
> 62 |     - Notebook management (list, create, rename, delete)
  63 |     - Source management (add, sync, delete)
  64 |     - Query/chat operations
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#184 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/client.py:63](#)

High-risk permission pattern: - Source management (add, sync, delete)

```
61 |     This class extends BaseClient with all domain-specific operations:
62 |     - Notebook management (list, create, rename, delete)
> 63 |     - Source management (add, sync, delete)
  64 |     - Query/chat operations
  65 |     - Studio content (audio, video, reports, flashcards, etc.)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#185 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/client.py:68](#)

High-risk permission pattern: - Notes management (create, list, update, delete)

```
66 |         - Research operations
67 |         - Sharing and collaboration
68 |         - Notes management (create, list, update, delete)
69 | ...
70 |     All HTTP/RPC infrastructure is provided by the BaseClient base class.
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#186 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/notebooklm_tools/core/client.py:20](#)

Dependency without integrity verification

```
18 |
19 | # Import utility functions from utils module
20 | # Import dataclasses from data_types module (re-exported for backward compatibility)
21 | # Import exception classes from errors module (re-exported for backward compatibility)
22 | from .errors import (
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#187 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/core/client.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | #!/usr/bin/env python3
   2 | """NotebookLM MCP API client (notebooklm.google.com).
   3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#188 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/collections.py:62](#)

High-risk permission pattern: # 2. Delete the temporary collection in the background

```
60 |         )
61 |
> 62 |         # 2. Delete the temporary collection in the background
63 |         if temp_id:
64 |             try:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#189 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/core/constants.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | ""
   2 | Constants and mappings for NotebookLM API...
   3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#190 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/conversation.py:332](#)

High-risk permission pattern: ""Delete the chat history for a notebook.

```
330 |
331 | def delete_chat_history(self, notebook_id: str, conversation_id: str) -> bool:
> 332 |     ""Delete the chat history for a notebook.
333 |
334 |     Args:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#191 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/conversation.py:336](#)

High-risk permission pattern: conversation_id: The conversation UUID to delete

```
334 |     Args:
335 |         notebook_id: The notebook UUID
> 336 |         conversation_id: The conversation UUID to delete
337 |
338 |     Returns:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#192 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/core/conversation.py:12](#)

Dynamic HTTP with sensitive data context

```
10 | import os
11 | import time
> 12 | import urllib.parse
13 | from typing import Any, Protocol, cast...
14 |
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#193 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/core/conversation.py:504](#)

Dynamic HTTP with sensitive data context

```
502 |
503 | # URL encode with safe='' to encode all characters including /
> 504 | body_parts = [f"f.req={urllib.parse.quote(f_req_json, safe='')}"]
505 | if self.csrf_token:
506 |     body_parts.append(f"at={urllib.parse.quote(self.csrf_token, safe='')}")
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#194 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/core/conversation.py:506](#)

Dynamic HTTP with sensitive data context

```
504 | body_parts = [f"f.req={urllib.parse.quote(f_req_json, safe='')}"]
505 | if self.csrf_token:
> 506 |     body_parts.append(f"at={urllib.parse.quote(self.csrf_token, safe='')}")
507 | # Add trailing & to match NotebookLM's format
508 | body = "&".join(body_parts) + "&"
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#195 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/core/conversation.py:527](#)

Dynamic HTTP with sensitive data context

```
525 | url_params["f.sid"] = self._session_id
526 |
> 527 | query_string = urllib.parse.urlencode(url_params)
528 | endpoint = getattr(self, "_get_query_endpoint", lambda: self.QUERY_ENDPOINT)()
529 | url = f"{self._get_base_url()}{endpoint}?{query_string}"
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#196 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/core/data_types.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | # src/notebooklm_tools/core/data_types.py
   2 | """Dataclasses for NotebookLM API client...
   3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#197 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/download.py:190](#)

High-risk permission pattern: cookies.delete("__OSID", domain=domain)

```
188 |         # an invalid session and redirects to ServiceLogin, breaking downloads.
189 |         for domain in (".google.com", ".googleusercontent.com"):
> 190 |             cookies.delete("__OSID", domain=domain)
191 |             cookies.delete("__Secure-OSID", domain=domain)
192 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#198 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/download.py:191](#)

High-risk permission pattern: cookies.delete("__Secure-OSID", domain=domain)

```
189 |         for domain in (".google.com", ".googleusercontent.com"):
190 |             cookies.delete("__OSID", domain=domain)
> 191 |             cookies.delete("__Secure-OSID", domain=domain)
192 |
193 |         # Per-chunk timeouts: 10s connect, 30s per chunk read/write
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#199 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/download.py:294](#)

High-risk permission pattern: `cookies.delete("OSID", domain=domain)`

```
292 |         cookies = self._get_httpx_cookies()
293 |         for domain in (".google.com", ".googleusercontent.com"):
> 294 |             cookies.delete("OSID", domain=domain)
295 |             cookies.delete("__Secure-OSID", domain=domain)...
296 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#200 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/download.py:295](#)

High-risk permission pattern: `cookies.delete("__Secure-OSID", domain=domain)`

```
293 |         for domain in (".google.com", ".googleusercontent.com"):
294 |             cookies.delete("OSID", domain=domain)
> 295 |             cookies.delete("__Secure-OSID", domain=domain)
296 |
297 |         timeout = httpx.Timeout(connect=10.0, read=30.0, write=30.0, pool=30.0)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#201 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

[src/notebooklm_tools/core/download.py:168](#)

File input near prompt/instruction handling — injection vector

```
166 |         {"User-Agent": "Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36"},
167 |     )
> 168 |     # Mirror Chrome's window.open() from notebooklm.google.com to a cross-domain
169 |     # artifact host (lh3.googleusercontent.com / lh3.google.com). The audio CDN
170 |     # treats "Sec-Fetch-Site: none" as an address-bar navigation and returns 403;
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#202 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

[src/notebooklm_tools/core/download.py:171](#)

File input near prompt/instruction handling — injection vector

```
169 |         # artifact host (lh3.googleusercontent.com / lh3.google.com). The audio CDN
170 |         # treats "Sec-Fetch-Site: none" as an address-bar navigation and returns 403;
> 171 |         # the UI's Download button succeeds because window.open() makes Chrome stamp
172 |         # the request with "Sec-Fetch-Site: cross-site" + Referer=notebooklm.google.com.
173 |         headers = {
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#203 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

[src/notebooklm_tools/core/download.py:229](#)

File input near prompt/instruction handling — injection vector

```
227 |  
> 228 | # Not an auth error - write first chunk and continue  
229 | with open(temp_file, "wb") as f:  
230 |     f.write(first_chunk)...  
231 |     bytes_downloaded = len(first_chunk)
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#204 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

[src/notebooklm_tools/core/download.py:246](#)

File input near prompt/instruction handling — injection vector

```
244 | # Binary content - stream directly  
> 245 | bytes_downloaded = 0  
246 | with open(temp_file, "wb") as f:  
247 |     async for chunk in response.aiter_bytes(chunk_size=chunk_size):  
248 |         f.write(chunk)
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#205 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

[src/notebooklm_tools/core/download.py:306](#)

File input near prompt/instruction handling — injection vector

```
304 | ):  
> 305 |     response.raise_for_status()  
306 |     with open(temp_file, "wb") as output:  
307 |         for chunk in response.iter_bytes(chunk_size=65536):  
308 |             output.write(chunk)
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#206 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

[src/notebooklm_tools/core/download.py:1142](#)

File input near prompt/instruction handling — injection vector

```
1140 |         output.parent.mkdir(parents=True, exist_ok=True)
1141 |
> 1142 |         with open(output, "w", newline="", encoding="utf-8-sig") as f:
1143 |             writer = csv.writer(f)
1144 |             writer.writerow(headers)
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#207 AS-005 -- INJECTION PATTERN

CRITICAL

OWASP: AA-02 | MITRE: T1055 | STRIDE: Tampering

Known prompt injection, SQL injection, XSS, or command injection patterns

[src/notebooklm_tools/core/download.py:1352](#)

Known injection pattern detected

```
1350 |         Tries multiple extraction patterns for robustness:
1351 |         1. data-app-data attribute (primary)
> 1352 |         2. <script id="application-data"> tag (fallback)
1353 |         3. Other common patterns
1354 |
```

Remediation:

1. Validate and sanitize all inputs with strict allowlists. 2. Use parameterized queries for any database access (never string concatenation). 3. HTML-encode all agent output before rendering. 4. Implement content security policy (CSP) headers. 5. Block known injection patterns at the input boundary.

#208 AS-005 -- INJECTION PATTERN

CRITICAL

OWASP: AA-02 | MITRE: T1055 | STRIDE: Tampering

Known prompt injection, SQL injection, XSS, or command injection patterns

[src/notebooklm_tools/core/download.py:1380](#)

Known injection pattern detected

```
1378 |         logger.debug(f"JSON preview: {decoded_json[:200]}...")
1379 |
> 1380 |         # Pattern 2: <script id="application-data"> tag
1381 |         match = re.search(
1382 |             r'<script[^>]+id=["\']application-data["\'][^>]*>(.*?)</script>',
```

Remediation:

1. Validate and sanitize all inputs with strict allowlists. 2. Use parameterized queries for any database access (never string concatenation). 3. HTML-encode all agent output before rendering. 4. Implement content security policy (CSP) headers. 5. Block known injection patterns at the input boundary.

#209 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/core/download.py:12](#)

Dynamic HTTP with sensitive data context

```
10 | from pathlib import Path
11 | from typing import Any
> 12 | from urllib.parse import urlparse
13 |
14 | import httpx
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#210 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/core/errors.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | # src/notebooklm_tools/core/errors.py
  2 | """Exception classes for NotebookLM API artifacts and client errors....
  3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#211 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/exceptions.py:159](#)

High-risk permission pattern: f"Delete it with 'nlm source delete {source_id}' if it is no longer needed."

```
157 |             hint=(
158 |                 "The failed source entry was retained for inspection. "
> 159 |                 f"Delete it with 'nlm source delete {source_id}' if it is no longer needed."
160 |             ),
161 |         )
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#212 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/core/exceptions.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Custom exceptions for NLM CLI."""
  2 |
  3 | from typing import Any
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#213 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/core/exports.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | #!/usr/bin/env python3
    2 | """ExportMixin - Export artifacts to Google Docs/Sheets....
    3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#214 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/labels.py:88](#)

High-risk permission pattern: """Delete one or more labels. Sources are NOT deleted."""

```
86 |
87 |     def delete_labels(self, notebook_id: str, label_ids: list[str]) -> bool:
88 |         """Delete one or more labels. Sources are NOT deleted."""
89 |         params = [[2], notebook_id, label_ids]
90 |         result = self._call_rpc(self.RPC_LABEL_DELETE, params, f"/notebook/{notebook_id}")
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#215 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/core/labels.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """LabelsMixin - Source label management operations.
    2 |
    3 | Requires 5+ sources for auto-label to be available in the NotebookLM UI.
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#216 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/core/models.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Pydantic models for NotebookLM data structures."""
    2 |
    3 | from datetime import datetime
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#217 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/notebooks.py:10](#)

High-risk permission pattern: - delete_notebook: Delete a notebook

```
8 | - rename_notebook: Rename a notebook
9 | - configure_chat: Configure chat settings
> 10 | - delete_notebook: Delete a notebook
11 |     """"...
12 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#218 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/notebooks.py:259](#)

High-risk permission pattern: """"Delete a notebook permanently.

```
257 |
258 |     def delete_notebook(self, notebook_id: str) -> bool:
> 259 |         """"Delete a notebook permanently.
260 |
261 |         WARNING: This action is IRREVERSIBLE. The notebook and all its sources,
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#219 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/notebooks.py:265](#)

High-risk permission pattern: notebook_id: The notebook UUID to delete

```
263 |
264 |     Args:
> 265 |         notebook_id: The notebook UUID to delete
266 |
267 |     Returns:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#220 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/notes.py:203](#)

High-risk permission pattern: """"Delete a note permanently.

```
201 |
202 |     def delete_note(self, note_id: str, notebook_id: str) -> bool:
> 203 |         """"Delete a note permanently.
204 |
205 |         Args:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#221 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/notes.py:216](#)

High-risk permission pattern: # Returns null on success (soft-delete: clears content, keeps ID)

```
214 |         self._call_rpc(self.RPC_DELETE_NOTE, params, f"/notebook/{notebook_id}")
215 |
> 216 |         # Returns null on success (soft-delete: clears content, keeps ID)
217 |         return True # If no exception was raised, consider it success...
218 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#222 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/core/notes.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """NotesMixin - Note management operations.
2 |
3 | This mixin provides note-related operations:
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#223 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/core/research.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | #!/usr/bin/env python3
2 | """Research mixin for NotebookLM client.
3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#224 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/retry.py:99](#)

High-risk permission pattern: `"""Execute a callable with retry logic for transient server errors.`

```
97 |         **kwargs: Any,  
> 98 |     ) -> Any:  
99 |         """Execute a callable with retry logic for transient server errors.  
100 | ...  
101 |         Use this for one-off retry wrapping where a decorator isn't practical
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#225 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/retry.py:105](#)

High-risk permission pattern: `func: The callable to execute.`

```
103 |  
104 |     Args:  
> 105 |         func: The callable to execute.  
106 |         *args: Positional arguments for the callable.  
107 |         max_retries: Maximum retry attempts.
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#226 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/core/sharing.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """SharingMixin - Notebook sharing and collaboration operations.  
2 |  
3 | This mixin provides sharing-related operations:
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#227 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/sources.py:6](#)

High-risk permission pattern: `- delete_source: Delete a source permanently`

```
4 | - check_source_freshness: Check if Drive source is up-to-date  
5 | - sync_drive_source: Sync a Drive source with latest content  
> 6 | - delete_source: Delete a source permanently  
7 | - get_notebook_sources_with_types: Get sources with type info  
8 | - add_url_source: Add URL/YouTube as source
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#228 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/sources.py:270](#)

High-risk permission pattern: """Delete a source from a notebook permanently.

```
268 |  
> 269 |         def delete_source(self, source_id: str) -> bool:  
270 |             """Delete a source from a notebook permanently.  
271 | ...  
272 |             WARNING: This action is IRREVERSIBLE. The source will be permanently
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#229 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/sources.py:276](#)

High-risk permission pattern: source_id: The source UUID to delete

```
274 |  
> 275 |         Args:  
276 |             source_id: The source UUID to delete  
277 |  
278 |         Returns:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#230 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/sources.py:281](#)

High-risk permission pattern: # Delete source params: [[["source_id"]], [2]]

```
279 |         """ True on success, False on failure  
280 |  
> 281 |         # Delete source params: [[["source_id"]], [2]]  
282 |         # Note: Extra nesting compared to delete_notebook  
283 |         params = [[["source_id"], [2]]
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#231 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/sources.py:291](#)

High-risk permission pattern: `"""Delete multiple sources from a notebook in a single request.`

```
289 |  
> 290 |     def delete_sources(self, source_ids: list[str]) -> bool:  
    291 |         """Delete multiple sources from a notebook in a single request.  
    292 | ...  
    293 |         WARNING: This action is IRREVERSIBLE. All specified sources will be
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#232 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/sources.py:297](#)

High-risk permission pattern: `source_ids: List of source UUIDs to delete`

```
295 |  
> 296 |     Args:  
    297 |         source_ids: List of source UUIDs to delete  
    298 |  
    299 |     Returns:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#233 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/sources.py:302](#)

High-risk permission pattern: `# Batch delete params: [[["id1"], ["id2"], ...], [2]]`

```
300 |         True on success, False on failure  
301 |         """  
> 302 |         # Batch delete params: [[["id1"], ["id2"], ...], [2]]  
    303 |         params = [[sid for sid in source_ids], [2]]  
    304 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#234 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/core/sources.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """SourceMixin - Source management operations.  
  2 |  
  3 | This mixin provides source-related operations:
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#235 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/studio.py:639](#)

High-risk permission pattern: `"""Delete a studio artifact (Audio, Video, or Mind Map).`

```
637 |  
638 |     def delete_studio_artifact(self, artifact_id: str, notebook_id: str | None = None) -> bool:  
> 639 |         """Delete a studio artifact (Audio, Video, or Mind Map).  
640 | ...  
641 |         WARNING: This action is IRREVERSIBLE. The artifact will be permanently deleted.
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#236 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/studio.py:644](#)

High-risk permission pattern: `artifact_id: The artifact UUID to delete`

```
642 |  
643 |     Args:  
> 644 |         artifact_id: The artifact UUID to delete  
645 |         notebook_id: Optional notebook ID. Required for deleting Mind Maps.  
646 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#237 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/studio.py:661](#)

High-risk permission pattern: `"Standard studio delete failed, trying fallback: %s", _e`

```
659 |  
660 |         _logging.getLogger(__name__).debug(  
> 661 |             "Standard studio delete failed, trying fallback: %s", _e  
662 |         )  
663 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#238 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/studio.py:672](#)

High-risk permission pattern: `"""Delete a Mind Map artifact using the observed two-step RPC sequence.`

```
670 |  
671 |     def delete_mind_map(self, notebook_id: str, mind_map_id: str) -> bool:  
> 672 |         """Delete a Mind Map artifact using the observed two-step RPC sequence.  
673 |  
674 |         Args:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#239 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/core/utils.py:4](#)

Dynamic HTTP with sensitive data context

```
2 |  
> 3 | import json  
4 | import urllib.parse  
5 | from datetime import UTC, datetime...  
6 | from typing import Any
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#240 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/core/utils.py:68](#)

Dynamic HTTP with sensitive data context

```
66 |     result = {}  
67 |     try:  
> 68 |         parsed = urllib.parse.parse_qs(body.rstrip("&"))  
69 |         if "f.req" in parsed:  
70 |             f_req_raw = parsed["f.req"][0]
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#241 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/core/utils.py:98](#)

Dynamic HTTP with sensitive data context

```
96 |     """Parse URL query parameters for debug display."""  
97 |     try:  
> 98 |         parsed = urllib.parse.urlparse(url)  
99 |         params = urllib.parse.parse_qs(parsed.query)  
100 |         return {k: v[0] if len(v) == 1 else v for k, v in params.items()}
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#242 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/core/utils.py:99](#)

Dynamic HTTP with sensitive data context

```
97 |     try:
98 |         parsed = urllib.parse.urlparse(url)
> 99 |         params = urllib.parse.parse_qs(parsed.query)
100 |         return {k: v[0] if len(v) == 1 else v for k, v in params.items()}...
101 |     except Exception:
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#243 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/mcp/__init__.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """MCP server interface for Gemini Notebook."""
  2 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#244 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/server.py:17](#)

High-risk permission pattern: - notes.py: Note management (create, list, update, delete)

```
15 | - chat.py: Query and conversation management
16 | - exports.py: Export artifacts to Google Docs/Sheets
> 17 | - notes.py: Note management (create, list, update, delete)
18 |     """
19 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#245 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/server.py:61](#)

High-risk permission pattern: - note(action=create|list|update|delete): Manage notes in notebooks

```
59 | - download_artifact(artifact_type=audio|video|...): Download any artifact type
60 | - download_all_artifacts: Download every completed artifact of a notebook into a per-notebook folder
> 61 | - note(action=create|list|update|delete): Manage notes in notebooks
62 | - label(action=auto|list|reorganize|create|rename|set_emoji|move_source|delete): Manage source
  labels"""
63 | )
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#246 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/server.py:62](#)

High-risk permission pattern: - label(action=auto|list|reorganize|create|rename|set_emoji|move_source|delete):

```
60 | - download_all_artifacts: Download every completed artifact of a notebook into a per-notebook folder
61 | - note(action=create|list|update|delete): Manage notes in notebooks
> 62 | - label(action=auto|list|reorganize|create|rename|set_emoji|move_source|delete): Manage source
    labels""",
63 | }...
64 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#247 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/mcp/tool_groups.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Optional group-based gating of MCP tools.
    2 |
    3 | The server registers a large tool set (49 tools). Clients that only need a
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#248 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/__init__.py:104](#)

High-risk permission pattern: # Studio (5 - consolidated create + revise + status + delete + interactive report)

```
102 |     "research_status",
103 |     "research_import",
> 104 |     # Studio (5 - consolidated create + revise + status + delete + interactive report)
105 |     "studio_create",
106 |     "studio_status",
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#249 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/__init__.py:122](#)

High-risk permission pattern: # Labels (1 consolidated — action: auto|list|reorganize|create|rename|set_emoji|

```
120 | # Notes (1 consolidated)
121 | "note",
> 122 | # Labels (1 consolidated — action: auto|list|reorganize|create|rename|set_emoji|move_source|
delete)
123 | "label", ...
124 | # Server (1)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#250 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/__init__.py:127](#)

High-risk permission pattern: # Batch (1 consolidated — action: query|add_source|create|delete|studio)

```
125 | "server_info",
126 | "usage_get",
> 127 | # Batch (1 consolidated — action: query|add_source|create|delete|studio)
128 | "batch",
129 | # Cross-notebook (1)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#251 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/mcp/tools/__init__.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """MCP tools - Modular tool definitions for the Gemini Notebook MCP server."""
2 |
3 | # Import all tools from submodules for registration
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#252 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/mcp/tools/auth.py:5](#)

Dynamic HTTP with sensitive data context

```
3 | import os
4 | import time
> 5 | import urllib.parse
6 | from http.cookies import SimpleCookie
7 |
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#253 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/mcp/tools/auth.py:155](#)

Dynamic HTTP with sensitive data context

```
153 |         # Try to extract CSRF token from request body if provided
154 |         if not csrf_token and request_body:
> 155 |             body_params = urllib.parse.parse_qs(request_body, keep_blank_values=True)
156 |             csrf_token = body_params.get("at", [""])[0]...
157 |
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#254 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/mcp/tools/auth.py:161](#)

Dynamic HTTP with sensitive data context

```
159 |         build_label = ""
160 |         if request_url:
> 161 |             parsed_url = urllib.parse.urlparse(request_url)
162 |             query = parsed_url.query or request_url
163 |             url_params = urllib.parse.parse_qs(query, keep_blank_values=True)
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#255 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/mcp/tools/auth.py:163](#)

Dynamic HTTP with sensitive data context

```
161 |         parsed_url = urllib.parse.urlparse(request_url)
162 |         query = parsed_url.query or request_url
> 163 |         url_params = urllib.parse.parse_qs(query, keep_blank_values=True)
164 |         if not session_id:
165 |             session_id = url_params.get("f.sid", [""])[0]
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#256 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/batch.py:26](#)

High-risk permission pattern: - delete: Delete multiple notebooks (IRREVERSIBLE, requires confirm=True)

```
24 |         - add_source: Add the same source URL to multiple notebooks
25 |         - create: Create multiple notebooks at once
> 26 |         - delete: Delete multiple notebooks (IRREVERSIBLE, requires confirm=True)
27 |         - studio: Generate studio artifacts across multiple notebooks...
28 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#257 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/batch.py:30](#)

High-risk permission pattern: action: Operation to perform (query, add_source, create, delete, studio)

```
28 |
29 |     Args:
> 30 |         action: Operation to perform (query, add_source, create, delete, studio)
31 |         query: Question to ask (for action=query)
32 |         source_url: URL to add (for action=add_source)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#258 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/batch.py:38](#)

High-risk permission pattern: confirm: Must be True for delete action

```
36 |         tags: Comma-separated tags to select notebooks
37 |         all: Apply to ALL notebooks
> 38 |         confirm: Must be True for delete action
39 |         """
40 |         try:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#259 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/batch.py:74](#)

High-risk permission pattern: elif action == "delete":

```
72 |         return {"status": "success", **result}
73 |
> 74 |         elif action == "delete":
75 |             if not confirm:
76 |                 return {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#260 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/batch.py:78](#)

High-risk permission pattern: "error": "Batch delete not confirmed. Ask the user to confirm before setting con

```
76 |         return {
77 |             "status": "error",
78 |             "error": "Batch delete not confirmed. Ask the user to confirm before setting
> confirm=True.",
79 |             "warning": "This action is IRREVERSIBLE. Multiple notebooks will be permanently
80 |         deleted."
    |     }
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#261 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/batch.py:93](#)

High-risk permission pattern: "error": f"Unknown action: {action}. Use: query, add_source, create, delete, stu

```
91 |         return {
92 |             "status": "error",
93 |             "error": f"Unknown action: {action}. Use: query, add_source, create, delete, studio",
> 94 |         }
95 |     }
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#262 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/mcp/tools/batch.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Batch operations – consolidated tool for multi-notebook actions."""
  2 |
  3 | from ...services import batch as batch_service
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#263 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/mcp/tools/chat.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Chat tools - Query and conversation management."""
    2 | ...
    3 | import functools
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#264 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/mcp/tools/chats.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """MCP tools for notebook chat sessions."""
    2 |
    3 | from notebooklm_tools.mcp.tools._utils import ResultDict, error_result, logged_tool
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#265 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/collections.py:80](#)

High-risk permission pattern: """Delete a collection permanently. Notebooks inside the collection are NOT dele

```
78 | @logged_tool()
79 | def collection_delete(collection_id: str, confirm: bool = False) -> ResultDict:
> 80 |     """Delete a collection permanently. Notebooks inside the collection are NOT deleted.
    81 |
    82 |     Args:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#266 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/mcp/tools/collections.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Collection tools - native NotebookLM collections management operations."""
    2 |
    3 | from ...services import ServiceError
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#267 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/mcp/tools/cross_notebook.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Cross-notebook tools – query across multiple notebooks."""
  2 | ...
  3 | from ...services import cross_notebook as cross_notebook_service
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#268 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/mcp/tools/downloads.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Download tools - Consolidated download_artifact for all artifact types."""
  2 |
  3 | import asyncio
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#269 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/mcp/tools/exports.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Export tools - Export artifacts to Google Docs/Sheets."""
  2 |
  3 | from ...services import ServiceError
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#270 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/labels.py:25](#)

High-risk permission pattern: Supports: auto, list, reorganize, create, rename, set_emoji, move_source, delete

```
23 |     for auto-labeling. Sources can belong to multiple labels simultaneously.
24 |
> 25 |     Supports: auto, list, reorganize, create, rename, set_emoji, move_source, delete
26 |
27 |     Args:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#271 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/labels.py:37](#)

High-risk permission pattern: - delete: Delete label(s) permanently (requires label_id or label_ids, confirm=T

```
35 |         - set_emoji: Set or clear emoji on a label (requires label_id, emoji)
36 |         - move_source: Assign a source to a label (requires label_id, source_id)
> 37 |         - delete: Delete label(s) permanently (requires label_id or label_ids, confirm=True)
38 |         label_id: Label UUID (required for rename, set_emoji, move_source, delete)...
39 |         label_ids: List of label UUIDs for batch delete (alternative to label_id)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#272 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/labels.py:38](#)

High-risk permission pattern: label_id: Label UUID (required for rename, set_emoji, move_source, delete)

```
36 |         - move_source: Assign a source to a label (requires label_id, source_id)
37 |         - delete: Delete label(s) permanently (requires label_id or label_ids, confirm=True)
> 38 |         label_id: Label UUID (required for rename, set_emoji, move_source, delete)
39 |         label_ids: List of label UUIDs for batch delete (alternative to label_id)
40 |         name: Label display name (required for create and rename)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#273 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/labels.py:39](#)

High-risk permission pattern: label_ids: List of label UUIDs for batch delete (alternative to label_id)

```
37 |         - delete: Delete label(s) permanently (requires label_id or label_ids, confirm=True)
38 |         label_id: Label UUID (required for rename, set_emoji, move_source, delete)
> 39 |         label_ids: List of label UUIDs for batch delete (alternative to label_id)
40 |         name: Label display name (required for create and rename)
41 |         emoji: Emoji character for set_emoji (e.g. "ðŸŒˆ"), or "" to clear
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#274 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/labels.py:45](#)

High-risk permission pattern: confirm: Must be True for delete action and for reorganize with unlabeled_only=F

```
43 |         unlabeled_only: For reorganize: if True, only label sources not yet in any label.
44 |         If False (default), replaces ALL existing labels from scratch (requires confirm=True).
> 45 |         confirm: Must be True for delete action and for reorganize with unlabeled_only=False
46 |
47 |     Returns:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#275 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/labels.py:59](#)

High-risk permission pattern: `label(notebook_id="abc", action="delete", label_id="xyz", confirm=True)`

```
57 |         label(notebook_id="abc", action="set_emoji", label_id="xyz", emoji="0<β~")
> 58 |         label(notebook_id="abc", action="move_source", label_id="xyz", source_id="src-id")
59 |         label(notebook_id="abc", action="delete", label_id="xyz", confirm=True)
60 |         """...
61 |         valid_actions = (
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#276 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/labels.py:69](#)

High-risk permission pattern: `"delete"`,

```
67 |         "set_emoji",
> 68 |         "move_source",
69 |         "delete",
70 |     )
71 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#277 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/labels.py:130](#)

High-risk permission pattern: `elif action == "delete":`

```
128 |         return {"status": "success", "action": "move_source", **result}
129 |
> 130 |         elif action == "delete":
131 |             ids = coerce_list(label_ids) or ([label_id] if label_id else None)
132 |             if not ids:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#278 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/labels.py:133](#)

High-risk permission pattern: `return error_result("label_id or label_ids is required for action='delete'")`

```
131 |         ids = coerce_list(label_ids) or ([label_id] if label_id else None)
132 |         if not ids:
> 133 |             return error_result("label_id or label_ids is required for action='delete'")
134 |         if not confirm:...
135 |             return error_result(
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#279 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/labels.py:140](#)

High-risk permission pattern: `return {"status": "success", "action": "delete", **result}`

```
138 |         )
139 |         result = labels_service.delete_labels(client, notebook_id, ids)
> 140 |         return {"status": "success", "action": "delete", **result}
141 |
142 |         return error_result(f"Unhandled action: {action}")
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#280 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/mcp/tools/labels.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Label tools - Source label management with consolidated label tool."""
2 |
3 | from ...services import ServiceError, ValidationError
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#281 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/notebooks.py:116](#)

High-risk permission pattern: `"""Delete notebook permanently. IRREVERSIBLE. Requires confirm=True.`

```
114 | @logged_tool()
115 | def notebook_delete(notebook_id: str, confirm: bool = False) -> ResultDict:
> 116 |     """Delete notebook permanently. IRREVERSIBLE. Requires confirm=True.
117 |
118 |     Args:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#282 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/mcp/tools/notebooks.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Notebook tools - Notebook management operations."""
   2 | ...
   3 | from ...services import ServiceError
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#283 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/notes.py:19](#)

High-risk permission pattern: Supports: create, list, update, delete

```
> 17 | """Manage notes in a notebook. Unified tool for all note operations.
   18 |
   19 | Supports: create, list, update, delete
   20 |
   21 | Args:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#284 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/notes.py:27](#)

High-risk permission pattern: - delete: Delete a note permanently (requires confirm=True)

```
> 25 | - list: List all notes in notebook
   26 | - update: Update an existing note
   27 | - delete: Delete a note permanently (requires confirm=True)
   28 | note_id: Note UUID (required for update/delete)
   29 | content: Note content (required for create, optional for update)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#285 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/notes.py:28](#)

High-risk permission pattern: note_id: Note UUID (required for update/delete)

```
26 |         - update: Update an existing note
27 |         - delete: Delete a note permanently (requires confirm=True)
> 28 |         note_id: Note UUID (required for update/delete)
29 |         content: Note content (required for create, optional for update)...
30 |         title: Note title (optional for create/update)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#286 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/notes.py:31](#)

High-risk permission pattern: confirm: Must be True for delete action

```
29 |         content: Note content (required for create, optional for update)
30 |         title: Note title (optional for create/update)
> 31 |         confirm: Must be True for delete action
32 |
33 |     Returns:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#287 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/notes.py:40](#)

High-risk permission pattern: note(notebook_id="abc", action="delete", note_id="xyz", confirm=True)

```
38 |         note(notebook_id="abc", action="create", content="My note", title="Title")
39 |         note(notebook_id="abc", action="update", note_id="xyz", content="Updated")
> 40 |         note(notebook_id="abc", action="delete", note_id="xyz", confirm=True)
41 |         """
42 |         valid_actions = ("create", "list", "update", "delete")
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#288 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/notes.py:42](#)

High-risk permission pattern: valid_actions = ("create", "list", "update", "delete")

```
40 |         note(notebook_id="abc", action="delete", note_id="xyz", confirm=True)
41 |         """
> 42 |         valid_actions = ("create", "list", "update", "delete")
43 |
44 |         if action not in valid_actions:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#289 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/notes.py:67](#)

High-risk permission pattern: `elif action == "delete":`

```
65 |         return {"status": "success", "action": "update", **update_result}
66 |
> 67 |         elif action == "delete":
68 |             if not note_id:
69 |                 return error_result("note_id is required for action='delete'")
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#290 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/notes.py:69](#)

High-risk permission pattern: `return error_result("note_id is required for action='delete'")`

```
67 |         elif action == "delete":
68 |             if not note_id:
> 69 |                 return error_result("note_id is required for action='delete'")
70 |             if not confirm:
71 |                 return error_result(
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#291 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/notes.py:76](#)

High-risk permission pattern: `return {"status": "success", "action": "delete", **delete_result}`

```
74 |         )
75 |         delete_result = notes_service.delete_note(client, notebook_id, note_id)
> 76 |         return {"status": "success", "action": "delete", **delete_result}
77 |
78 |         return error_result(f"Unhandled action: {action}")
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#292 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/mcp/tools/notes.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Notes tools - Note management with consolidated note tool."""
    2 | ...
    3 | from ...services import ServiceError, ValidationError
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#293 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/pipeline.py:15](#)

High-risk permission pattern: """Manage and execute multi-step notebook pipelines.

```
> 13 |         input_url: str = "",
    14 |     ) -> ResultDict:
    15 |         """Manage and execute multi-step notebook pipelines.
    16 |
    17 |         Actions:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#294 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/pipeline.py:18](#)

High-risk permission pattern: - run: Execute a pipeline on a notebook

```
> 16 |
    17 |     Actions:
    18 |     - run: Execute a pipeline on a notebook
    19 |     - list: List all available pipelines (builtin and user-defined)
    20 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#295 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/mcp/tools/pipeline.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Pipeline tools – consolidated tool for multi-step notebook workflows."""
    2 |
    3 | from ...services import pipeline as pipeline_service
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#296 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/mcp/tools/research.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Research tools - Deep research and source discovery."""
    2 | ...
    3 | from ...services import ServiceError
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#297 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/notebooklm_tools/mcp/tools/server.py:163](#)

Dependency without integrity verification

```
161 |         "auth_status": _check_auth_status(),
162 |         "update_command": "uv tool upgrade notebooklm-mcp-cli",
> 163 |         "pip_update_command": "pip install --upgrade notebooklm-mcp-cli",
164 |         "mcp_capabilities": _runtime_capabilities(),
165 |         "provider_capabilities": {
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#298 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/mcp/tools/server.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Server tools - Server info and version checking."""
    2 |
    3 | import json
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#299 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/mcp/tools/server.py:4](#)

Dynamic HTTP with sensitive data context

```
2 |
3 | import json
> 4 | import urllib.request
    5 | from typing import Any, cast
    6 |
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#300 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/mcp/tools/server.py:20](#)

Dynamic HTTP with sensitive data context

```
18 |         try:
19 |             url = "https://pypi.org/pypi/notebooklm-mcp-cli/json"
> 20 |             req = urllib.request.Request(url, headers={"User-Agent": "notebooklm-mcp-cli"})
21 |             with urllib.request.urlopen(req, timeout=2) as response: # nosec B310 - URL is hardcoded to
https://pypi.org...
22 |                 data = cast(dict[str, Any], json.loads(response.read().decode()))
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#301 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/mcp/tools/server.py:21](#)

Dynamic HTTP with sensitive data context

```
19 |         url = "https://pypi.org/pypi/notebooklm-mcp-cli/json"
20 |         req = urllib.request.Request(url, headers={"User-Agent": "notebooklm-mcp-cli"})
> 21 |         with urllib.request.urlopen(req, timeout=2) as response: # nosec B310 - URL is hardcoded to
https://pypi.org
22 |             data = cast(dict[str, Any], json.loads(response.read().decode()))
23 |             info = data.get("info")
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#302 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/mcp/tools/sharing.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Sharing tools - Notebook sharing and collaboration."""
2 |
3 | from ...services import ServiceError
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#303 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/mcp/tools/smart_select.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Smart select tools - consolidated tag management and notebook selection."""
2 |
3 | from ...services import smart_select as smart_select_service
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#304 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/sources.py:191](#)

High-risk permission pattern: """Delete source(s) permanently. IRREVERSIBLE. Requires confirm=True.

```
189 |         confirm: bool = False,
190 |     ) -> ResultDict:
> 191 |         """Delete source(s) permanently. IRREVERSIBLE. Requires confirm=True.
192 |         ...
193 |         Args:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#305 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/sources.py:194](#)

High-risk permission pattern: source_id: Source UUID to delete (single)

```
192 |
193 |     Args:
> 194 |         source_id: Source UUID to delete (single)
195 |         source_ids: List of source UUIDs to delete (bulk, alternative to source_id)
196 |         confirm: Must be True after user approval
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#306 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/sources.py:195](#)

High-risk permission pattern: source_ids: List of source UUIDs to delete (bulk, alternative to source_id)

```
193 |     Args:
194 |         source_id: Source UUID to delete (single)
> 195 |         source_ids: List of source UUIDs to delete (bulk, alternative to source_id)
196 |         confirm: Must be True after user approval
197 |         """
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#307 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/sources.py:210](#)

High-risk permission pattern: # Bulk delete: when source_ids list is provided

```
208 |         coerced_source_ids: list[str] | None = coerce_list(source_ids)
209 |
> 210 |         # Bulk delete: when source_ids list is provided
211 |         if coerced_source_ids:
212 |             sources_service.delete_sources(client, coerced_source_ids)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#308 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/sources.py:219](#)

High-risk permission pattern: # Single delete (existing behavior)

```
217 |         }
218 |
> 219 |         # Single delete (existing behavior)
220 |         if not source_id:
221 |             return error_result("Either source_id or source_ids is required.")
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#309 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/mcp/tools/sources.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Source tools - Source management with consolidated source_add."""
2 |
3 | from ...services import ServiceError, ValidationError
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#310 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/studio.py:510](#)

High-risk permission pattern: """Delete studio artifact. IRREVERSIBLE. Requires confirm=True.

```
508 |         confirm: bool = False,
509 |     ) -> ResultDict:
> 510 |         """Delete studio artifact. IRREVERSIBLE. Requires confirm=True.
511 |
512 |         Args:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#311 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/mcp/tools/studio.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Studio tools - Artifact creation with consolidated studio_create."""
   2 | ...
   3 | import json
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#312 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/mcp/tools/studio_advanced.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Studio advanced – helper for studio type reference data."""
   2 |
   3 | from typing import Any
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#313 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/mcp/tools/usage.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Usage tools - plan allowance windows and subscription tier."""
   2 |
   3 | from ...services import ServiceError
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#314 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/services/__init__.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Service layer for NotebookLM MCP CLI.
   2 |
   3 | This package contains the shared business logic, validation, and error handling
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#315 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/services/_compat.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Python version compatibility shims for the services layer."""
    2 | ...
    3 | import sys
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#316 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/services/auth_replay.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Auth replay diagnostics for NotebookLM credentials."""
    2 |
    3 | from __future__ import annotations
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#317 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/services/auth_replay.py:245](#)

Dynamic HTTP with sensitive data context

```
243 |         return _fail("NotebookLM page loaded, but session fields were not found.")
    244 |
> 245 |         from urllib.parse import urlparse
    246 |
    247 |         csrf_token = cdp.extract_csrf_token(html) or profile.csrf_token or ""
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#318 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/batch.py:53](#)

High-risk permission pattern: `"""Execute a function across multiple targets in parallel."""`

```
51 |         max_concurrent: int = 5,  
52 |     ) -> BatchResult:  
> 53 |         """Execute a function across multiple targets in parallel."""  
54 |         results: list[BatchItemResult] = [...]  
55 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#319 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/batch.py:199](#)

High-risk permission pattern: `"""Delete multiple notebooks.`

```
197 |         max_concurrent: int = 3,  
198 |     ) -> BatchResult:  
> 199 |         """Delete multiple notebooks.  
200 |  
201 |         Args:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#320 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/batch.py:203](#)

High-risk permission pattern: `notebook_names: Notebooks to delete`

```
201 |         Args:  
202 |             client: Authenticated client  
> 203 |             notebook_names: Notebooks to delete  
204 |             tags: Select by tags  
205 |             confirm: Must be True (safety check)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#321 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/batch.py:210](#)

High-risk permission pattern: `"Batch delete requires confirm=True.",`

```
208 |         if not confirm:  
209 |             raise ValidationError(  
> 210 |                 "Batch delete requires confirm=True.",  
211 |                 user_message="Batch delete is IRREVERSIBLE. Set confirm=True after user approval.",  
212 |             )
```


Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#322 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/batch.py:211](#)

High-risk permission pattern: user_message="Batch delete is IRREVERSIBLE. Set confirm=True after user approval"

```
209 |         raise ValidationError(  
210 |             "Batch delete requires confirm=True.",  
> 211 |             user_message="Batch delete is IRREVERSIBLE. Set confirm=True after user approval.",  
212 |         )...  
213 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#323 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/services/batch.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Batch operations service – perform operations across multiple notebooks."""  
2 |  
3 | from concurrent.futures import ThreadPoolExecutor, as_completed
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#324 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/chat.py:380](#)

High-risk permission pattern: """Delete the chat history for a notebook.

```
378 |         notebook_id: str,  
379 |     ) -> DeleteChatHistoryResult:  
> 380 |         """Delete the chat history for a notebook.  
381 |  
382 |         Fetches the notebook's persistent conversation ID, then deletes
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#325 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/chat.py:399](#)

High-risk permission pattern: `user_message="This notebook has no chat history to delete."`,

```
397 |         raise ServiceError(  
398 |             "No chat history found for this notebook.",  
> 399 |             user_message="This notebook has no chat history to delete.",  
400 |         )...  
401 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#326 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/chat.py:405](#)

High-risk permission pattern: `raise ServiceError(f"Failed to delete chat history: {e}") from e`

```
403 |         client.delete_chat_history(notebook_id, conv_id)  
404 |     except Exception as e:  
> 405 |         raise ServiceError(f"Failed to delete chat history: {e}") from e  
406 |  
407 |     return {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#327 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/collections.py:92](#)

High-risk permission pattern: `"""Permanently delete a collection.`

```
90 |  
91 | def delete_collection(client: NotebookLMClient, collection_id: str) -> dict:  
> 92 |     """Permanently delete a collection.  
93 |  
94 |     Args:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#328 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/collections.py:104](#)

High-risk permission pattern: `raise ServiceError(f"Failed to delete collection: {e}") from e`

```
102 |         raise ServiceError("Google backend returned falsy result for collection deletion")  
103 |     except Exception as e:  
> 104 |         raise ServiceError(f"Failed to delete collection: {e}") from e  
105 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#329 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/services/collections.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Collections service – shared business logic for native collections CRUD and metadata
  2 | operations."""
  3 | from ..core.client import NotebookLMClient
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#330 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/services/cross_notebook.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Cross-notebook query service – query multiple notebooks and aggregate results."""
  2 |
  3 | from concurrent.futures import ThreadPoolExecutor, as_completed
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#331 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/services/downloads.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Downloads service – shared validation and routing for artifact downloads."""
  2 |
  3 | import asyncio
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#332 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/services/errors.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Service layer errors and exceptions."""
    2 | ...
    3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#333 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/services/exports.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Export service – shared business logic for Google Docs/Sheets exports."""
    2 |
    3 | from typing import Literal, cast
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#334 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/services/interactive_reports.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Interactive report services: reads, element settings, planning and generation.
    2 |
    3 | cli/ and mcp/ call these (directly or via the re-exports in services.studio);
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#335 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/labels.py:275](#)

High-risk permission pattern: """Delete one or more labels. Sources are NOT deleted.

```
273 |     label_ids: list[str],
274 | ) -> LabelDeleteResult:
> 275 |     """Delete one or more labels. Sources are NOT deleted.
    276 |
    277 |     Args:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#336 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/labels.py:280](#)

High-risk permission pattern: `label_ids`: List of label UUIDs to delete

```
278 |         client: Authenticated NotebookLM client
279 |         notebook_id: Notebook UUID
> 280 |         label_ids: List of label UUIDs to delete
281 | ...
282 |     Returns:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#337 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/labels.py:291](#)

High-risk permission pattern: `"label_ids is required."`, `user_message="Provide at least one label ID to delete."`

```
289 |         if not label_ids:
290 |             raise ValidationError(
> 291 |                 "label_ids is required.", user_message="Provide at least one label ID to delete."
292 |             )
293 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#338 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/labels.py:303](#)

High-risk permission pattern: `raise ServiceError(f"Failed to delete labels: {e}") from e`

```
301 |         result = client.delete_labels(notebook_id, clean_ids)
302 |         except Exception as e:
> 303 |             raise ServiceError(f"Failed to delete labels: {e}") from e
304 |
305 |         if not result:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#339 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/labels.py:306](#)

High-risk permission pattern: `raise ServiceError("Delete returned falsy result", user_message="Failed to delet`

```
304 |
305 |         if not result:
> 306 |             raise ServiceError("Delete returned falsy result", user_message="Failed to delete labels.")
307 |
308 |         count = len(clean_ids)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#340 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/services/labels.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Labels service – shared business logic for source label management."""
  2 | ...
  3 | from ..core.client import NotebookLMClient
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#341 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/notebooks.py:333](#)

High-risk permission pattern: """Delete a notebook permanently.

```
331 |     notebook_id: str,
332 | ) -> NotebookDeleteResult:
> 333 |     """Delete a notebook permanently.
334 |
335 |     Args:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#342 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/notebooks.py:348](#)

High-risk permission pattern: raise ServiceError(f"Failed to delete notebook: {e}") from e

```
346 |         result = client.delete_notebook(notebook_id)
347 |     except Exception as e:
> 348 |         raise ServiceError(f"Failed to delete notebook: {e}") from e
349 |
350 |     if result:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#343 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/notebooks.py:357](#)

High-risk permission pattern: `user_message="Failed to delete notebook — no confirmation from API."`,

```
355 |         raise ServiceError(  
356 |             "Notebook deletion returned falsy result",  
> 357 |             user_message="Failed to delete notebook — no confirmation from API.",  
358 |         )...  
359 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#344 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/services/notebooks.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Notebooks service — shared business logic for notebook CRUD and metadata operations."""  
2 |  
3 | import httpx
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#345 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/notes.py:179](#)

High-risk permission pattern: `"""Delete a note permanently.`

```
177 |         note_id: str,  
178 |     ) -> NoteDeleteResult:  
> 179 |         """Delete a note permanently.  
180 |  
181 |         Args:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#346 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/notes.py:195](#)

High-risk permission pattern: `raise ServiceError(f"Failed to delete note: {e}") from e`

```
193 |         result = client.delete_note(note_id, notebook_id)  
194 |         except Exception as e:  
> 195 |             raise ServiceError(f"Failed to delete note: {e}") from e  
196 |  
197 |         if result:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#347 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/notes.py:205](#)

High-risk permission pattern: user_message="Failed to delete note — no confirmation from API."

```
203 |         raise ServiceError(  
204 |             "Note deletion returned falsy result",  
205 |             user_message="Failed to delete note – no confirmation from API.",  
206 |         )...  
207 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#348 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/services/notes.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Notes service – shared business logic for note CRUD operations."""  
2 |  
3 | from ..core.client import NotebookLMClient
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#349 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/pipeline.py:1](#)

High-risk permission pattern: """Pipeline automation service — define and execute multi-step notebook workflow

```
> 1 | """Pipeline automation service – define and execute multi-step notebook workflows."""  
2 |  
3 | import re
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#350 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/pipeline.py:152](#)

High-risk permission pattern: """Execute a single pipeline step."""

```
150 |         params: dict,  
151 |     ) -> Any:  
> 152 |         """Execute a single pipeline step."""  
153 |         if action == "source_add":  
154 |             source_type = params.get("type", "url")
```


Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#351 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/pipeline.py:202](#)

High-risk permission pattern: ""Execute a pipeline by name.

```
200 |         variables: dict[str, str] | None = None,
201 |     ) -> PipelineResult:
202 |         """Execute a pipeline by name.
203 |         ...
204 |         Args:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#352 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/services/pipeline.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Pipeline automation service – define and execute multi-step notebook workflows."""
   2 |
   3 | import re
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#353 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/services/research.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Research service – shared business logic for research start, poll, and import."""
   2 |
   3 | import re
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#354 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/services/sharing.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Sharing service – shared business logic for notebook sharing and collaboration."""
  2 | ...
  3 | import re
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#355 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/services/smart_select.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Smart select service – tag management and intelligent notebook selection."""
  2 |
  3 | import json
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#356 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/sources.py:580](#)

High-risk permission pattern: """Delete a source permanently.

```
578 |         source_id: str,
579 |     ) -> None:
> 580 |         """Delete a source permanently.
581 |
582 |         Args:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#357 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/sources.py:593](#)

High-risk permission pattern: f"Delete returned falsy for source {source_id}",

```
591 |         if not result:
592 |             raise ServiceError(
> 593 |                 f"Delete returned falsy for source {source_id}",
594 |                 user_message="Failed to delete source.",
595 |             )
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#358 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/sources.py:594](#)

High-risk permission pattern: `user_message="Failed to delete source."`,

```
592 |         raise ServiceError(  
593 |             f"Delete returned falsy for source {source_id}",  
> 594 |             user_message="Failed to delete source.",  
595 |         )...  
596 |     except ServiceError:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#359 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/sources.py:600](#)

High-risk permission pattern: `f"Failed to delete source {source_id}: {e}"`,

```
598 |     except Exception as e:  
599 |         raise ServiceError(  
> 600 |             f"Failed to delete source {source_id}: {e}",  
601 |             user_message="Failed to delete source.",  
602 |         ) from e
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#360 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/sources.py:601](#)

High-risk permission pattern: `user_message="Failed to delete source."`,

```
599 |         raise ServiceError(  
600 |             f"Failed to delete source {source_id}: {e}",  
> 601 |             user_message="Failed to delete source.",  
602 |         ) from e  
603 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#361 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/sources.py:609](#)

High-risk permission pattern: `"""Delete multiple sources permanently in a single request.`

```
607 |         source_ids: list[str],  
608 |     ) -> None:  
> 609 |         """Delete multiple sources permanently in a single request.  
610 |  
611 |         Args:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#362 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/sources.py:613](#)

High-risk permission pattern: source_ids: List of source UUIDs to delete

```
611 |     Args:
612 |         client: Authenticated NotebookLM client
> 613 |         source_ids: List of source UUIDs to delete
614 |     ...
615 |     Raises:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#363 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/sources.py:620](#)

High-risk permission pattern: raise ValidationError("No source IDs provided for bulk delete.")

```
618 |     """
619 |     if not source_ids:
> 620 |         raise ValidationError("No source IDs provided for bulk delete.")
621 |
622 |     try:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#364 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/sources.py:626](#)

High-risk permission pattern: f"Bulk delete returned falsy for {len(source_ids)} sources",

```
624 |         if not result:
625 |             raise ServiceError(
> 626 |                 f"Bulk delete returned falsy for {len(source_ids)} sources",
627 |                 user_message="Failed to delete sources.",
628 |             )
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#365 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/sources.py:627](#)

High-risk permission pattern: `user_message="Failed to delete sources."`,

```
625 |         raise ServiceError(  
626 |             f"Bulk delete returned falsy for {len(source_ids)} sources",  
> 627 |             user_message="Failed to delete sources.",  
628 |         )...  
629 |     except (ValidationError, ServiceError):
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#366 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/sources.py:633](#)

High-risk permission pattern: `f"Failed to delete {len(source_ids)} sources: {e}"`,

```
631 |     except Exception as e:  
632 |         raise ServiceError(  
> 633 |             f"Failed to delete {len(source_ids)} sources: {e}",  
634 |             user_message="Failed to delete sources.",  
635 |         ) from e
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#367 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/sources.py:634](#)

High-risk permission pattern: `user_message="Failed to delete sources."`,

```
632 |         raise ServiceError(  
633 |             f"Failed to delete {len(source_ids)} sources: {e}",  
> 634 |             user_message="Failed to delete sources.",  
635 |         ) from e  
636 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#368 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/services/sources.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Sources service – shared validation and logic for source management."""  
2 |  
3 | import os
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#369 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/services/sources.py:5](#)

Dynamic HTTP with sensitive data context

```
3 | import os
4 | import time
> 5 | import urllib.parse
6 | from concurrent.futures import ThreadPoolExecutor...
7 | from pathlib import Path
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#370 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/services/sources.py:179](#)

Dynamic HTTP with sensitive data context

```
177 |
178 |         if not url:
179 |             raise ValidationError("url is required for source_type='url'")
> 179 |         parsed = urllib.parse.urlparse(url)
180 |         if not parsed.scheme or parsed.scheme.lower() not in ALLOWED_URL_SCHEMES:
181 |             raise ValidationError()
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#371 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/studio.py:1](#)

High-risk permission pattern: """Studio service — artifact creation, status, rename, delete.

```
> 1 | """Studio service – artifact creation, status, rename, delete.
2 |
3 | Centralizes:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#372 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/studio.py:902](#)

High-risk permission pattern: # ----- Delete -----

```
900 |
901 |
> 902 | # ----- Delete -----
903 |
904 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#373 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/studio.py:910](#)

High-risk permission pattern: ""Delete a studio artifact permanently.

```
908 |     notebook_id: str,  
909 | ) -> None:  
> 910 |     """Delete a studio artifact permanently.  
911 | ...  
912 |     Raises:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#374 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/studio.py:919](#)

High-risk permission pattern: f"Delete returned falsy for artifact {artifact_id}",

```
917 |         if not result:  
918 |             raise ServiceError(  
> 919 |                 f"Delete returned falsy for artifact {artifact_id}",  
920 |                 user_message="Failed to delete artifact.",  
921 |             )
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#375 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/studio.py:920](#)

High-risk permission pattern: user_message="Failed to delete artifact.",

```
918 |         raise ServiceError(  
919 |             f"Delete returned falsy for artifact {artifact_id}",  
> 920 |             user_message="Failed to delete artifact.",  
921 |         )  
922 |     except ServiceError:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#376 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/studio.py:926](#)

High-risk permission pattern: f"Failed to delete artifact: {e}",

```
924 |         except Exception as e:
925 |             raise ServiceError(
> 926 |                 f"Failed to delete artifact: {e}",
927 |                 user_message="Could not delete artifact.",...
928 |             ) from e
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#377 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/studio.py:927](#)

High-risk permission pattern: user_message="Could not delete artifact.",

```
925 |             raise ServiceError(
926 |                 f"Failed to delete artifact: {e}",
> 927 |                 user_message="Could not delete artifact.",
928 |             ) from e
929 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#378 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/services/usage.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Usage service – plan allowance windows and subscription tier.
2 |
3 | Gemini Notebook meters usage as compute against two simultaneous windows: a
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#379 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/utils/__init__.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Utility functions shared across the package."""
2 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#380 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/notebooklm_tools/utils/auth_browser.py:95](#)

Dependency without integrity verification

```
93 |         raise AuthenticationError(  
94 |             message="No supported browser found",  
> 95 |             hint=f"Install {browser_text}, or use 'nrm login --manual' to import cookies from a  
file.",  
96 |         )...  
97 |
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#381 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/utils/auth_browser.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Browser/backend selection for interactive and headless authentication."""  
2 |  
3 | import json
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#382 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/utils/browser.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Browser cookie utilities."""  
2 |  
3 | import json
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#383 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/utils/cdp.py:1239](#)

High-risk permission pattern: """Execute a CDP command via WebSocket.

```
1237 |         response_timeout: float = 30,  
1238 |     ) -> dict:  
> 1239 |         """Execute a CDP command via WebSocket.  
1240 |  
1241 |         Args:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#384 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/utils/cdp.py:1491](#)

High-risk permission pattern: clear_profile: If True, delete the Chrome user-data-dir before launching

```
1489 |         login_timeout: Max seconds to wait for login
1490 |         profile_name: NLM profile name (each gets its own Chrome user-data-dir)
> 1491 |         clear_profile: If True, delete the Chrome user-data-dir before launching
1492 | ...
1493 |     Returns:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#385 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/utils/cdp.py:1545](#)

High-risk permission pattern: hint=f"Close any stuck browser processes or delete the SingletonLock file in the

```
1543 |         raise AuthenticationError(
1544 |             message="The NLM auth profile is locked but no browser instance was found",
> 1545 |             hint=f"Close any stuck browser processes or delete the SingletonLock file in the
{profile_name} browser profile.",
1546 |         )
1547 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#386 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

[src/notebooklm_tools/utils/cdp.py:248](#)

File input near prompt/instruction handling — injection vector

```
246 |     map_file = _get_port_map_file()
247 |     try:
> 248 |         fd = os.open(str(map_file), os.O_WRONLY | os.O_CREAT | os.O_TRUNC, 0o600)
249 |         try:
250 |             f = os.fdopen(fd, "w", encoding="utf-8")
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#387 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

[src/notebooklm_tools/utils/cdp.py:250](#)

File input near prompt/instruction handling — injection vector

```
248 |         fd = os.open(str(map_file), os.O_WRONLY | os.O_CREAT | os.O_TRUNC, 0o600)
249 |         try:
> 250 |             f = os.fdopen(fd, "w", encoding="utf-8")
251 |         except BaseException:
252 |             os.close(fd)
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#388 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

[src/notebooklm_tools/utils/cdp.py:968](#)

File input near prompt/instruction handling — injection vector

```
966 |         try:
967 |             _logger.debug("Launching browser: %s on port %d", chrome_path, port)
> 968 |             process = subprocess.Popen(args, **kwargs) # nsec B603 – chrome_path from shutil.which();
args built from hardcoded flags + validated port
969 |             return process
970 |         except Exception as e:
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#389 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/utils/cdp.py:23](#)

Dynamic HTTP with sensitive data context

```
21 | from pathlib import Path
22 | from typing import Any
> 23 | from urllib.parse import quote, urlparse
24 |
25 | from httpx import Client, HTTPTransport
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#390 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/utils/config.py:14](#)

Dynamic HTTP with sensitive data context

```
12 | from pathlib import Path
13 | from typing import Any
> 14 | from urllib.parse import quote, urlparse
15 |
16 | from pydantic import BaseModel, Field
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#391 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/utils/config.py:90](#)

Dynamic HTTP with sensitive data context

```
88 |         export NOTEBOOKLM_BASE_URL=https://notebooklm.cloud.google.com
89 |         """
> 90 |         from urllib.parse import urlparse
91 |         ...
92 |         env_override = os.environ.get("NOTEBOOKLM_BASE_URL")
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#392 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/utils/env_sanitize.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Environment sanitization that must run before HTTP clients import."""
  2 |
  3 | import os
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#393 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/utils/firefox.py:78](#)

High-risk permission pattern: rows = snapshot.execute(

```
76 |         ):
77 |         source.backup(snapshot)
> 78 |         rows = snapshot.execute(
79 |             "SELECT name, value, host, path, expiry, isSecure, isHttpOnly FROM moz_cookies"
80 |         ).fetchall()
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#394 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

[src/notebooklm_tools/utils/firefox.py:102](#)

File input near prompt/instruction handling — injection vector

```
100 | def _launch_firefox(firefox_path: str, profile_dir: Path) -> subprocess.Popen[bytes]:
101 |     try:
102 |         return subprocess.Popen(
103 |             [...
104 |                 firefox_path,
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#395 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/utils/io_encoding.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Normalize stdio text encoding where platform defaults break Unicode (Windows).
2 |
3 | Windows consoles often default to cp1252. Typer/Rich then raise UnicodeEncodeError
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#396 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/utils/wsl.py:234](#)

High-risk permission pattern: "\n 2. Run: taskkill /f /im chrome.exe (in Windows PowerShell Admin)"

```
232 |                                     "\n\nPlease:"
233 |                                     "\n 1. Close ALL Chrome windows and tabs manually"
> 234 |                                     "\n 2. Run: taskkill /f /im chrome.exe (in Windows PowerShell Admin)"
235 |                                     "\n 3. Then retry: nlm login --wsl"
236 |                                     )
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#397 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/utils/wsl.py:518](#)

High-risk permission pattern: # This will trigger UAC prompt if not running as admin

```
516 |     try:
517 |         # Build PowerShell command to create firewall rule
> 518 |         # This will trigger UAC prompt if not running as admin
519 |         logger.info(f"Creating Windows Firewall rule for port {port}")
520 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#398 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

[src/notebooklm_tools/utils/wsl.py:338](#)

File input near prompt/instruction handling — injection vector

```
336 |         logger.debug(f"Chrome temp profile: {temp_dir}")
337 |         try:
> 338 |             process = subprocess.Popen( # nsec B603 B607 — args built from validated Chrome path +
hardcoded flags + int port
339 |                                     args,...
340 |                                     stdout=stdout_arg,
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#399 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/utils/wsl.py:365](#)

Dynamic HTTP with sensitive data context

```
363 |         True if CDP is ready, False if timeout.
364 |         """
> 365 |         import urllib.parse
366 |
367 |         parsed = urllib.parse.urlparse(cdp_url)
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#400 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/utils/wsl.py:367](#)

Dynamic HTTP with sensitive data context

```
365 |         import urllib.parse
366 |
> 367 |         parsed = urllib.parse.urlparse(cdp_url)
368 |         base_url = f"{parsed.scheme}://{parsed.hostname}:{parsed.port}"
369 |
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#401 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/cli/test_auth_refresh.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for the `nlm auth refresh` command (issue #316, suggestion #3)."""
  2 | ...
  3 | from types import SimpleNamespace
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#402 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/cli/test_chats_cli.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Unit tests for the chats CLI commands."""
  2 |
  3 | from unittest.mock import patch
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#403 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/cli/test_cli_main_errors.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for top-level CLI error rendering."""
  2 |
  3 | import pytest
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#404 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/cli/test_download_all.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for the `nlm download all` CLI command."""
  2 |
  3 | import json
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#405 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/cli/test_download_cli.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for individual artifact download CLI commands."""
  2 | ...
  3 | from unittest.mock import MagicMock, patch
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#406 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/cli/test_formatters.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | import json
  2 | from types import SimpleNamespace
  3 | from unittest.mock import patch
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#407 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/cli/test_json_parity.py:125](#)

High-risk permission pattern: ["delete", "src-1", "src-2", "--confirm", "--json"],

```
123 |         result = runner.invoke(
124 |             source.app,
> 125 |             ["delete", "src-1", "src-2", "--confirm", "--json"],
126 |         )
127 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#408 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/cli/test_json_parity.py:151](#)

High-risk permission pattern: ["delete", "nb-1", "--confirm", "--json"],

```
149 |         result = runner.invoke(
150 |             notebook.app,
> 151 |             ["delete", "nb-1", "--confirm", "--json"],
152 |         )
153 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#409 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/cli/test_json_parity.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """JSON output parity for mutating CLI commands."""
   2 | ...
   3 | import inspect
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#410 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/cli/test_login.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | from types import SimpleNamespace
   2 |
   3 | from typer.testing import CliRunner
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#411 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/cli/test_mcp_branding.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for the Gemini Notebook MCP branding contract."""
   2 |
   3 | from pathlib import Path
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#412 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/cli/test_repl.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for the interactive chat REPL."""
   2 |
   3 | from contextlib import nullcontext
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#413 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/cli/test_setup_claude_code.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Safety checks for Claude Code's user-level MCP configuration."""
  2 | ...
  3 | import json
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#414 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/cli/test_setup_claude_desktop.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for Claude Desktop support in ``nlm setup add/remove/list``."""
  2 |
  3 | import json
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#415 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/cli/test_setup_codex_desktop.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for shared Codex CLI and ChatGPT Desktop configuration."""
  2 |
  3 | from pathlib import Path
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#416 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/cli/test_setup_full_path.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for full-detected-binary-path defaults in MCP setup entries."""
  2 |
  3 | from notebooklm_tools.cli.commands import setup
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#417 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/cli/test_setup_github_copilot.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for GitHub Copilot support in `nlm setup add/remove/list`."""
  2 | ...
  3 | import json
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#418 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/cli/test_setup_json.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for the Copy-JSON snippet builder."""
  2 |
  3 | from notebooklm_tools.cli.commands import setup
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#419 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/cli/test_setup_list_status.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """The direct status command reports the same user-level targets as the wizard."""
  2 |
  3 | import json
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#420 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/cli/test_setup_opencode.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for OpenCode client support in `nlm setup add/remove/list`.
  2 |
  3 | Verifies that the OpenCode integration correctly handles the different
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#421 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/cli/test_setup_safety.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for safe configuration file handling and backups."""
  2 | ...
  3 | import json
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#422 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/cli/test_setup_skill_actions.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for safe skill actions: backup, deduplication, and version checking."""
  2 |
  3 | from pathlib import Path
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#423 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/cli/test_setup_status.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for the wizard status view row assembly."""
  2 |
  3 | from pathlib import Path
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#424 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/cli/test_setup_wizard.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for the interactive guided nlm setup wizard."""
  2 |
  3 | from pathlib import Path
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#425 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/cli/test_setup_wizard_e2e.py:405](#)

High-risk permission pattern: `w.expect("Delete the listed skill folders")`

```
403 | w.expect("Remove the selected MCP entries")
404 | w.send("y")
> 405 | w.expect("Delete the listed skill folders")
406 | w.send("y")...
407 | w.expect("Removal Results")
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#426 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/cli/test_setup_wizard_e2e.py:429](#)

High-risk permission pattern: `w.expect("Delete the listed skill folders")`

```
427 | w.expect("Remove the selected MCP entries")
428 | w.send(ENTER) # default: no
> 429 | w.expect("Delete the listed skill folders")
430 | w.send(ENTER) # default: no
431 | w.expect("Removal Results")
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#427 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/cli/test_setup_wizard_e2e.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """End-to-end tests: drive the real `nlm setup` wizard in a pseudo-terminal.
2 |
3 | Opt-in (slow): run with `uv run pytest -m wizard_e2e` after changing the setup
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#428 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/cli/test_skill_install.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for safe skill installation."""
2 |
3 | from unittest.mock import patch
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#429 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/cli/test_skill_package.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | import zipfile
   2 | from pathlib import Path...
   3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#430 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/cli/test_skill_version_state.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for skill.skill_version_state (install + version + upgrade info)."""
   2 |
   3 | from pathlib import Path
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#431 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/cli/test_source_add.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for the `nlm source add` CLI command, focusing on --youtube bulk support."""
   2 |
   3 | from unittest.mock import MagicMock, patch
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#432 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/cli/test_source_list.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for the `nlm source list` CLI command."""
   2 |
   3 | import json
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#433 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/cli/test_studio_cli.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for Studio CLI commands."""
  2 | ...
  3 | import json
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#434 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[tests/cli/test_usage_cli.py:74](#)

Potential secret: possible hardcoded secret

```
72 | from notebooklm_tools.services.auth import AuthManager
73 |
> 74 | AuthManager("work").save_profile(cookies={"SID": "work"}, csrf_token="work-csrf")
75 | monkeypatch.setenv("NOTEBOOKLM_COOKIES", "SID=personal")
76 | with (
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#435 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/cli/test_usage_cli.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """CLI tests for profile-aware plan usage reporting."""
  2 |
  3 | from unittest.mock import MagicMock, patch
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#436 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/cli/test_verbs_defaults.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests that verb command fallback defaults match valid CodeMapper values.
  2 |
  3 | Verbs in verbs.py use `xxx` or "fallback" patterns to provide defaults
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#437 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/cli/test_verbs_parity.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Test that verb wrappers pass all parameters their target functions accept.
  2 | ...
  3 | When a verb wrapper calls a target function directly (not through Typer),
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#438 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/cli/test_wizard_helpers.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for shared wizard picker-row model and questionnaire conversion."""
  2 |
  3 | from notebooklm_tools.cli.commands import setup_wizard as w
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#439 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

[tests/cli/wizard_driver.py:40](#)

File input near prompt/instruction handling — injection vector

```
38 | import json, os, pathlib, sys
39 | args = sys.argv[1:]
> 40 | with open(os.environ["WIZ_SHIM_LOG"], "a") as log:
41 |     log.write("claude " + " ".join(args) + "\n")
42 | if os.environ.get("WIZ_CLAUDE_FAIL"):
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#440 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

[tests/cli/wizard_driver.py:71](#)

File input near prompt/instruction handling — injection vector

```
69 | _LOG_SHIM = ""
70 | import os, sys
> 71 | with open(os.environ["WIZ_SHIM_LOG"], "a") as log:
72 |     log.write("{name} " + " ".join(sys.argv[1:]) + "\n")
73 | """
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#441 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

[tests/cli/wizard_driver.py:83](#)

File input near prompt/instruction handling — injection vector

```
81 | _PBCOPY_SHIM = ""
82 | import os, sys
> 83 | with open(os.environ["WIZ_CLIPBOARD"], "w") as f:
84 |     f.write(sys.stdin.read())...
85 | ""
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#442 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/cli/wizard_driver.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Drive the real `nlm setup` wizard in a pseudo-terminal against a sandboxed home.
2 |
3 | Used by test_setup_wizard_e2e.py. The wizard runs as a real subprocess with a
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#443 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/conftest.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Shared test fixtures."""
2 |
3 | import os
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#444 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/core/test_alias.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for alias type detection."""
2 |
3 | from contextlib import nullcontext
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#445 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[tests/core/test_auth_check.py:101](#)

Potential secret: possible hardcoded secret

```
99 |         "SAPISID": "dead",
100 |     },
> 101 |     csrf_token="stale123",
102 |     session_id="sess123", ...
103 |     email="test@example.com",
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#446 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[tests/core/test_auth_check.py:141](#)

Potential secret: possible hardcoded secret

```
139 |         "SAPISID": "dead",
140 |     },
> 141 |     csrf_token="stale123",
142 |     session_id="sess123",
143 |     email="test@example.com",
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#447 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/core/test_auth_check.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Test-driven development for the elegant unified auth validity check.
2 |
3 | The goal is a single source of truth:
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#448 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/core/test_auth_guard.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for account mismatch guard in profile saving."""
2 |
3 | from notebooklm_tools.core.exceptions import AccountMismatchError, AuthenticationError, NLMErr
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#449 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[tests/core/test_auth_recovery.py:26](#)

Potential secret: possible hardcoded secret

```
24 | def _make_client(cookies):
25 |     with patch.object(NotebookLMClient, "_refresh_auth_tokens"):
26 |         return NotebookLMClient(cookies=cookies, csrf_token="stale_token")
27 | ...
28 |
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#450 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[tests/core/test_auth_recovery.py:42](#)

Potential secret: possible hardcoded secret

```
40 |         if client.cookies == {"SID": "stale"}:
41 |             raise ValueError("Authentication expired. accounts.google.com login")
> 42 |         client.csrf_token = "fresh_token"
43 |
44 |         # Disk holds different (fresher) cookies than what is in memory.
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#451 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/core/test_auth_recovery.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Regression tests for long-lived auth recovery (issue #316).
2 |
3 | Covers two confirmed defects in ``BaseClient`` auth recovery:
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#452 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[tests/core/test_base.py:34](#)

Potential secret: possible hardcoded secret

```
32 |         # When csrf_token is provided, _refresh_auth_tokens should NOT be called
33 |         with patch.object(BaseClient, "_refresh_auth_tokens") as mock_refresh:
> 34 |             client = BaseClient(cookies={"test": "cookie"}, csrf_token="test_token")
35 |             mock_refresh.assert_not_called()
36 |             assert client.csrf_token == "test_token"
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#453 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[tests/core/test_base.py:73](#)

Potential secret: possible hardcoded secret

```
71 |  
> 72 |         with patch.object(BaseClient, "_refresh_auth_tokens"):  
73 |             client = BaseClient(cookies={}, csrf_token="test_token")  
74 |             body = client._build_request_body("testRpc", ["param1"])...  
75 |             assert "f.req=" in body
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#454 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[tests/core/test_base.py:85](#)

Potential secret: possible hardcoded secret

```
83 |  
> 84 |         with patch.object(BaseClient, "_refresh_auth_tokens"):  
85 |             client = BaseClient(cookies={}, csrf_token="test_token", session_id="test_sid")  
86 |             url = client._build_url("testRpc", "/notebook/123")  
87 |             assert "rpcids=testRpc" in url
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#455 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[tests/core/test_base.py:247](#)

Potential secret: possible hardcoded secret

```
245 |         cached = AuthTokens(  
246 |             cookies={"SID": "old"},  
> 247 |             csrf_token="old-csrf",  
248 |             session_id="old-session",  
249 |         )
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#456 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[tests/core/test_base.py:258](#)

Potential secret: possible hardcoded secret

```
256 |         client = BaseClient(  
257 |             cookies={"SID": "rotated"},  
> 258 |             csrf_token="new-csrf",  
259 |             session_id="new-session", ...  
260 |         )
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#457 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/core/test_base.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | # tests/core/test_base.py  
2 | """Tests for BaseClient infrastructure class."""  
3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#458 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/core/test_call_rpc_retry_flag.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """_call_rpc must be able to skip 5xx replays for non-idempotent kickoffs."""  
2 |  
3 | from unittest.mock import MagicMock
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#459 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[tests/core/test_cdp_transport.py:24](#)

Potential secret: possible hardcoded secret

```
22 |         client = BaseClient(  
23 |             cookies={"SID": "old"},  
> 24 |             csrf_token="old-csrf",  
25 |             session_id="old-session",  
26 |             build_label="old-build",
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#460 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[tests/core/test_cdp_transport.py:34](#)

Potential secret: possible hardcoded secret

```
32 |         def prepare_cdp_transport(self, timeout):
33 |             assert timeout == 45.0
> 34 |             self.csrf_token = "live-csrf"
35 |             self._session_id = "live-session"...
36 |             self._bl = "live-build"
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#461 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[tests/core/test_cdp_transport.py:71](#)

Potential secret: possible hardcoded secret

```
69 |         client = BaseClient(
70 |             cookies={"SID": "old"},
> 71 |             csrf_token="old-csrf",
72 |             session_id="old-session",
73 |             build_label="old-build",
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#462 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[tests/core/test_cdp_transport.py:84](#)

Potential secret: possible hardcoded secret

```
82 |         port=9222,
83 |         ws_url="ws://page",
> 84 |         csrf_token="live-csrf",
85 |         session_id="live-session",
86 |         build_label="live-build",
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#463 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[tests/core/test_cdp_transport.py:109](#)

Potential secret: possible hardcoded secret

```
107 |         mixin = ConversationMixin(
108 |             cookies={"SID": "old"},
> 109 |             csrf_token="old-csrf",
110 |             session_id="old-session",
111 |             build_label="old-build",
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#464 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[tests/core/test_cdp_transport.py:116](#)

Potential secret: possible hardcoded secret

```
114 |         def prepare_cdp_transport(self, timeout):
115 |             assert 0 < timeout <= 99.0
> 116 |             self.csrf_token = "live-csrf"
117 |             self._session_id = "live-session"...
118 |             self._bl = "live-build"
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#465 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[tests/core/test_cdp_transport.py:206](#)

Potential secret: possible hardcoded secret

```
204 |
205 |         with patch.object(BaseClient, "_refresh_auth_tokens"):
> 206 |             client = BaseClient(cookies={"SID": "old"}, csrf_token="old-csrf")
207 |
208 |         def fake_get_context(**kwargs):
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#466 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[tests/core/test_cdp_transport.py:213](#)

Potential secret: possible hardcoded secret

```
211 |             port=9230,
212 |             ws_url="ws://page",
> 213 |             csrf_token="live-csrf",
214 |             session_id="live-session",
215 |             build_label="live-build",
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#467 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/core/test_cdp_transport.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for the experimental CDP RPC transport."""
    2 | ...
    3 | import json
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#468 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[tests/core/test_cdp_transport.py:4](#)

Dynamic HTTP with sensitive data context

```
> 2 |
    3 | import json
    4 | import urllib.parse
    5 | from unittest.mock import patch
    6 |
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#469 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[tests/core/test_cdp_transport.py:53](#)

Dynamic HTTP with sensitive data context

```
> 51 |
    52 |     assert result == ["ok"]
    53 |     query_params = urllib.parse.parse_qs(urllib.parse.urlparse(captured["url"]).query)
    54 |     assert query_params["f.sid"] == ["live-session"]
    55 |     assert query_params["bl"] == ["live-build"]
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#470 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[tests/core/test_cdp_transport.py:56](#)

Dynamic HTTP with sensitive data context

```
> 54 |     assert query_params["f.sid"] == ["live-session"]
    55 |     assert query_params["bl"] == ["live-build"]
    56 |     body_params = urllib.parse.parse_qs(captured["body"])
    57 |     assert body_params["at"] == ["live-csrf"]
    58 |     assert captured["timeout"] == 45.0
```


Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#471 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[tests/core/test_cdp_transport.py:155](#)

Dynamic HTTP with sensitive data context

```
153 |     assert result["conversation_id"] == "server-conv"
154 |     assert "GenerateFreeFormStreamed" in str(captured["url"])
> 155 |     query_params = urllib.parse.parse_qs(urllib.parse.urlparse(str(captured["url"])).query)
156 |     assert query_params["f.sid"] == ["live-session"]...
157 |     assert query_params["bl"] == ["live-build"]
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#472 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[tests/core/test_cdp_transport.py:158](#)

Dynamic HTTP with sensitive data context

```
156 |     assert query_params["f.sid"] == ["live-session"]
157 |     assert query_params["bl"] == ["live-build"]
> 158 |     body_params = urllib.parse.parse_qs(str(captured["body"]))
159 |     assert body_params["at"] == ["live-csrf"]
160 |     assert 0 < captured["timeout"] <= 99.0
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#473 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/core/test_cookie_rotation.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | from __future__ import annotations
  2 |
  3 | import httpx
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#474 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/core/test_data_types.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | from notebooklm_tools.core.data_types import (  
  2 |     Collaborator,...  
  3 |     ConversationTurn,
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#475 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/core/test_download.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | #!/usr/bin/env python3  
  2 | """Tests for DownloadMixin."""  
  3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#476 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/core/test_errors.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | # tests/core/test_errors.py  
  2 | """Tests for artifact exception classes."""  
  3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#477 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/core/test_interactive_app_data.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | from unittest.mock import MagicMock  
  2 |  
  3 | from notebooklm_tools.core.download import DownloadMixin
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#478 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/core/test_manual_login_host.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Regression tests for manual-login host detection (issue #292)."""
  2 | ...
  3 | from types import SimpleNamespace
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#479 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/core/test_notebooks.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for NotebookMixin class."""
  2 |
  3 | from unittest.mock import MagicMock, patch
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#480 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/core/test_notes.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for NotesMixin class."""
  2 |
  3 | from unittest.mock import patch
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#481 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/core/test_research.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | #!/usr/bin/env python3
  2 | """Tests for ResearchMixin."""
  3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#482 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/core/test_retry.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | from unittest.mock import Mock, patch
    2 | ...
    3 | import httpx
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#483 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/core/test_rpc_errors.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for RPC drift detection and RPC-level retry in BaseClient."""
    2 |
    3 | from unittest.mock import Mock, patch
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#484 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/core/test_rpc_overrides.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for runtime RPC-ID override mechanism."""
    2 |
    3 | import json
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#485 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/core/test_sharing.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for SharingMixin class."""
    2 |
    3 | from unittest.mock import patch
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#486 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[tests/core/test_socks_proxy.py:33](#)

Potential secret: possible hardcoded secret

```
31 | def test_sync_client_initializes_with_socks_proxy_env(monkeypatch: pytest.MonkeyPatch) -> None:
32 |     _configure_socks_proxy(monkeypatch)
> 33 |     client = BaseClient(cookies={}, csrf_token="test-token")
34 | ...
35 |     http_client = client._get_client()
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#487 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[tests/core/test_socks_proxy.py:46](#)

Potential secret: possible hardcoded secret

```
44 | ) -> None:
45 |     _configure_socks_proxy(monkeypatch)
> 46 |     client = BaseClient(cookies={}, csrf_token="test-token")
47 |
48 |     http_client = client._get_async_client()
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#488 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/core/test_socks_proxy.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Regression tests for outbound SOCKS proxy support (Issue #237)."""
2 |
3 | import importlib.metadata
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#489 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/core/test_source_reconciliation.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for source reconciliation logic (Issue #196).
2 |
3 | Verifies that accepted-pending RPC errors (code 3 / code 9) are resolved
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#490 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/core/test_sources.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for SourceMixin class."""
   2 | ...
   3 | from unittest.mock import MagicMock, patch
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#491 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/core/test_studio.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | #!/usr/bin/env python3
   2 | """Tests for StudioMixin."""
   3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#492 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[tests/core/test_thread_safety.py:19](#)

Potential secret: possible hardcoded secret

```
17 |
18 |         with patch.object(BaseClient, "_refresh_auth_tokens"):
> 19 |             return NotebookLMClient(cookies={"test": "cookie"}, csrf_token="test_token")
   20 |
   21 |
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#493 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/core/test_thread_safety.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | # tests/core/test_thread_safety.py
   2 | """Tests for thread-safety of NotebookLMClient shared state.
   3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#494 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/core/test_url_source_fallback.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for dual RPC fallback in URL source addition (issue #121).
    2 | ...
    3 | These tests exercise the core layer's add_url_source and add_url_sources
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#495 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/core/test_utils.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | from notebooklm_tools.core.utils import (
    2 |     RPC_NAMES,
    3 |     extract_cookies_from_chrome_export,
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#496 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/manual/test_fastmcp_stdio.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | import asyncio
    2 | import sys
    3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#497 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/manual/test_revise_slide_deck.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | #!/usr/bin/env python3
    2 | """Manual test: Revise a slide deck via RPC KmCKPe.
    3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#498 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/services/__init__.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for the services layer."""...
    2 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#499 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[tests/services/test_auth_health.py:340](#)

Dangerous execution: usable, status, detail = __import__(

```
338 |         lambda: type("C", (), {"check": lambda self, **kw: report})()),
339 |     )
> 340 |     usable, status, detail = __import__(
341 |         "notebooklm_tools.services.auth", fromlist=["credentials_are_usable"]
342 |     ).credentials_are_usable()
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#500 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/services/test_auth_health.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for the AuthHealthChecker (multi-probe auth health check with caching).
    2 |
    3 | These tests pin:
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#501 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/services/test_auth_replay_diagnostic.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | from __future__ import annotations
    2 |
    3 | from notebooklm_tools.services.auth_replay import (
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#502 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[tests/services/test_auth_service.py:171](#)

Dangerous execution: exec(# nosec B102 - fixed literal import statement, no user input

```
169 | # Re-execute the import statement the same way cli code does.
170 | local_namespace = {}
> 171 | exec( # nosec B102 - fixed literal import statement, no user input
172 |     "from notebooklm_tools.services.auth import AuthManager", local_namespace...
173 | )
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#503 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/services/test_auth_service.py:169](#)

High-risk permission pattern: # Re-execute the import statement the same way cli code does.

```
167 |
168 | monkeypatch.setattr(core_auth, "AuthManager", sentinel_class, raising=True)
> 169 | # Re-execute the import statement the same way cli code does.
170 | local_namespace = {}
171 | exec( # nosec B102 - fixed literal import statement, no user input
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#504 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/services/test_auth_service.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for the services.auth re-export shim.
2 |
3 | The shim exists to satisfy the layering rule (cli/ and mcp/ must not import
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#505 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/services/test_batch.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for batch service – batch operations across notebooks."""
2 |
3 | from unittest.mock import MagicMock, patch
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#506 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/services/test_chat.py:317](#)

High-risk permission pattern: with `pytest.raises(ServiceError, match="Failed to delete")`:

```
315 |         mock_client.delete_chat_history.side_effect = RuntimeError("server error")
316 |
> 317 |         with pytest.raises(ServiceError, match="Failed to delete"):
318 |             delete_chat_history(mock_client, "nb-123")...
319 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#507 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/services/test_chat.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for services.chat module."""
2 |
3 | from unittest.mock import MagicMock, patch
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#508 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/services/test_chats_service.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Unit tests for the chats service layer (TDD)."""
2 |
3 | from unittest.mock import MagicMock, patch
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#509 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/services/test_cross_notebook.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for cross_notebook service – cross-notebook queries."""
2 |
3 | from unittest.mock import MagicMock, patch
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#510 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/services/test_download_containment.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Security tests: MCP downloads must stay inside an approved directory.
  2 | ...
  3 | Covers GHSA-92q4-9x75-55rf. ``validate_output_path`` used a denylist, so every
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#511 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/services/test_downloads.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for services.downloads module."""
  2 |
  3 | from unittest.mock import AsyncMock, MagicMock
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#512 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/services/test_errors.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for services.errors module."""
  2 |
  3 | import pytest
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#513 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/services/test_exports.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for services.exports module."""
  2 |
  3 | from unittest.mock import MagicMock
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#514 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/services/test_interactive_reports.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for interactive report support (type 11).
  2 | ...
  3 | Covers payload construction, artifact parsing, markdown rendering, element
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#515 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/services/test_notebooks.py:255](#)

High-risk permission pattern: with `pytest.raises(ServiceError, match="Failed to delete notebook")`:

```
253 |         def test_api_error_raises_service_error(self, mock_client):
254 |             mock_client.delete_notebook.side_effect = RuntimeError("fail")
> 255 |             with pytest.raises(ServiceError, match="Failed to delete notebook"):
256 |                 delete_notebook(mock_client, "nb-123")
257 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#516 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/services/test_notebooks.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for services.notebooks module."""
  2 |
  3 | from types import SimpleNamespace
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#517 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/services/test_notes.py:156](#)

High-risk permission pattern: with `pytest.raises(ServiceError, match="Failed to delete note")`:

```
154 |         def test_api_error_raises_service_error(self, mock_client):
155 |             mock_client.delete_note.side_effect = RuntimeError("fail")
> 156 |             with pytest.raises(ServiceError, match="Failed to delete note"):
157 |                 delete_note(mock_client, "nb-123", "note-1")
158 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#518 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/services/test_notes.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for services.notes module."""
  2 | ...
  3 | from unittest.mock import MagicMock
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#519 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/services/test_pipeline.py:197](#)

High-risk permission pattern: (pipeline_dir / "delete-test.yaml").write_text(

```
195 |         pipeline_dir = pipelines_dir / "pipelines"
196 |         pipeline_dir.mkdir(parents=True, exist_ok=True)
> 197 |         (pipeline_dir / "delete-test.yaml").write_text(
198 |             yaml.dump(
199 |                 {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#520 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/services/test_pipeline.py:200](#)

High-risk permission pattern: "name": "delete-test",

```
198 |         yaml.dump(
199 |             {
> 200 |                 "name": "delete-test",
201 |                 "steps": [{"action": "notebook_delete", "params": {}}],
202 |             }
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#521 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/services/test_pipeline.py:206](#)

High-risk permission pattern: result = pipeline_run(mock_client, "nb-001", "delete-test")

```
204 |         )
205 |
> 206 |         result = pipeline_run(mock_client, "nb-001", "delete-test")
207 |         assert result["succeeded"] == 1
208 |         mock_notebooks.delete_notebook.assert_called_once_with(mock_client, "nb-001")
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#522 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/services/test_pipeline.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for pipeline service – multi-step workflow automation."""
   2 | ...
   3 | from unittest.mock import MagicMock, patch
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#523 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/services/test_pipeline_path_traversal.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Path-traversal regression tests for pipeline names (GHSA-596g-p98x-c7hw).
   2 |
   3 | `_load_pipeline` (read, reachable over MCP) and `pipeline_create` (write, CLI)
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#524 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/services/test_report_element_generation.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Single and batch element generation share one safe path."""
   2 |
   3 | from unittest.mock import MagicMock
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#525 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[tests/services/test_report_element_plans.py:59](#)

Unrestricted agent autonomy: parse_element_plan([{"element_id": "x", "auto_approve": True}])

```
> 57 | def test_parse_rejects_unknown_keys():
   58 |     with pytest.raises(ValidationError, match="unknown"):
   59 |         parse_element_plan([{"element_id": "x", "auto_approve": True}])
   60 |
   61 |
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use `tool_choice='none'` or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: [npm install mcp-secure](#)

#526 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/services/test_report_element_plans.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Plan parsing and validation must finish before any Google mutation."""
  2 | ...
  3 | from unittest.mock import MagicMock
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include `agent_id`, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#527 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/services/test_report_element_wait.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | from unittest.mock import MagicMock
  2 |
  3 | from notebooklm_tools.services.interactive_reports import REVIEW_LABEL, list_report_elements
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include `agent_id`, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#528 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/services/test_research.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for services.research module."""
  2 |
  3 | from unittest.mock import MagicMock, patch
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include `agent_id`, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#529 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/services/test_sharing.py:149](#)

High-risk permission pattern: `invite_collaborator(mock_client, "nb-123", "alice@example.com", "admin")`

```
147 |     def test_invalid_role_raises_validation_error(self, mock_client):
148 |         with pytest.raises(ValidationError, match="Invalid role"):
> 149 |             invite_collaborator(mock_client, "nb-123", "alice@example.com", "admin")
150 | ...
151 |     def test_role_case_insensitive(self, mock_client):
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#530 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/services/test_sharing.py:218](#)

High-risk permission pattern: `{"email": "alice@example.com", "role": "admin"}`,

```
216 |     def test_invalid_role_raises_validation_error(self, mock_client):
217 |         recipients = [
> 218 |             {"email": "alice@example.com", "role": "admin"},
219 |         ]
220 |         with pytest.raises(ValidationError, match="Invalid role"):
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#531 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/services/test_sharing.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for services.sharing module."""
  2 |
  3 | from dataclasses import dataclass
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#532 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/services/test_smart_select.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for smart_select service – tag management and intelligent notebook selection."""
  2 |
  3 | import json
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#533 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/services/test_sources.py:44](#)

High-risk permission pattern: # Sync/delete/describe/content

```
42 | ]
43 | client.check_source_freshness.return_value = True
> 44 | # Sync/delete/describe/content
45 | client.sync_drive_source.return_value = True...
46 | client.delete_source.return_value = True
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#534 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/services/test_sources.py:509](#)

High-risk permission pattern: with pytest.raises(ServiceError, match="Delete returned falsy"):

```
507 | def test_falsy_result_raises(self, mock_client):
508 |     mock_client.delete_source.return_value = False
> 509 |     with pytest.raises(ServiceError, match="Delete returned falsy"):
510 |         delete_source(mock_client, "src-1")
511 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#535 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/services/test_sources.py:514](#)

High-risk permission pattern: with pytest.raises(ServiceError, match="Failed to delete"):

```
512 | def test_api_error(self, mock_client):
513 |     mock_client.delete_source.side_effect = RuntimeError("fail")
> 514 |     with pytest.raises(ServiceError, match="Failed to delete"):
515 |         delete_source(mock_client, "src-1")
516 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#536 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/services/test_sources.py:706](#)

High-risk permission pattern: with pytest.raises(ServiceError, match="Bulk delete returned falsy"):

```
704 | def test_falsy_result_raises(self, mock_client):
705 |     mock_client.delete_sources.return_value = False
> 706 |     with pytest.raises(ServiceError, match="Bulk delete returned falsy"):
707 |         delete_sources(mock_client, ["s1"])
708 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#537 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/services/test_sources.py:711](#)

High-risk permission pattern: with `pytest.raises(ServiceError, match="Failed to delete")`:

```
709 |         def test_api_error(self, mock_client):
710 |             mock_client.delete_sources.side_effect = RuntimeError("fail")
> 711 |             with pytest.raises(ServiceError, match="Failed to delete"):
712 |                 delete_sources(mock_client, ["s1"])...
713 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#538 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/services/test_sources.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for services.sources module."""
  2 |
  3 | import os
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#539 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/services/test_studio.py:57](#)

High-risk permission pattern: # Rename/delete

```
55 |         {"mind_map_id": "mm-1", "title": "Map 1"},
56 |     ]
> 57 |     # Rename/delete
58 |     client.rename_studio_artifact.return_value = True
59 |     client.delete_studio_artifact.return_value = True
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#540 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/services/test_studio.py:646](#)

High-risk permission pattern: with `pytest.raises(ServiceError, match="Delete returned falsy")`:

```
644 |     def test_falsy_result(self, mock_client):
645 |         mock_client.delete_studio_artifact.return_value = False
> 646 |         with pytest.raises(ServiceError, match="Delete returned falsy"):
647 |             delete_artifact(mock_client, "art-1", "nb-1")...
648 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#541 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/services/test_studio.py:651](#)

High-risk permission pattern: with `pytest.raises(ServiceError, match="Failed to delete")`:

```
649 |     def test_api_error(self, mock_client):
650 |         mock_client.delete_studio_artifact.side_effect = RuntimeError("fail")
> 651 |         with pytest.raises(ServiceError, match="Failed to delete"):
652 |             delete_artifact(mock_client, "art-1", "nb-1")
653 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#542 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/services/test_studio.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for services.studio module."""
2 |
3 | import json
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#543 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/services/test_usage.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for the usage service.
2 |
3 | Fixtures are trimmed copies of real `EylDcb` responses captured from the live
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#544 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/services/test_usage_profiles.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Named usage checks load only the requested account and release its client."""
  2 | ...
  3 | from unittest.mock import patch
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#545 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[tests/test_api_client.py:15](#)

Potential secret: possible hardcoded secret

```
13 |     cookies = {"SID": "test_sid"}
14 |     with patch.object(NotebookLMClient, "_refresh_auth_tokens"):
> 15 |         client = NotebookLMClient(cookies=cookies, csrf_token="old_token", session_id="old_sid")
16 |         return client
17 |
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#546 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/test_api_client.py:152](#)

High-risk permission pattern: # Execute

```
150 |         ]
151 |
> 152 |         # Execute
153 |         result = mock_client._call_rpc("rLM1Ne", [])
154 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#547 AS-005 -- INJECTION PATTERN

CRITICAL

OWASP: AA-02 | MITRE: T1055 | STRIDE: Tampering

Known prompt injection, SQL injection, XSS, or command injection patterns

[tests/test_api_client.py:166](#)

Known injection pattern detected

```
164 |         # Simplified HTML to minimize whitespace issues
165 |         # api_client.py looks for "FdrFJe":..." for the session ID
> 166 |         html = '<html><script>WIZ_global_data = {"SNlM0e":"new_csrf_token", "FdrFJe":"123456789"};</
script></html>'
167 |
168 |         # Restore the original method for this test
```

Remediation:

1. Validate and sanitize all inputs with strict allowlists. 2. Use parameterized queries for any database access (never string concatenation). 3. HTML-encode all agent output before rendering. 4. Implement content security policy (CSP) headers. 5. Block known injection patterns at the input boundary.

#548 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/test_api_client.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | import json
   2 | from unittest.mock import MagicMock, patch...
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#549 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/test_auth_browser.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for supported authentication browser behavior."""
   2 |
   3 | import json
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#550 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/test_auth_migration.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests to validate auth works after removing notebooklm-mcp-auth.
   2 |
   3 | These tests verify that:
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#551 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/test_base_host_capture.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Regression tests for capturing the signed-in host during login (issue #269).
   2 |
   3 | Google's "Gemini Notebook" rebrand redirects some migrated accounts to
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#552 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/test_base_url_resolution.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Regression tests for NotebookLM base-URL host resolution (issue #269).
  2 | ...
  3 | Google is rolling out a rebrand of NotebookLM to "Gemini Notebook" at
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#553 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/test_cdp_headless_port.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Headless auth must not launch on a hardcoded port that a foreign process
  2 | may already hold, which would let it probe the wrong browser (issue #330)."""
  3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#554 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/test_cdp_port_map.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Regression tests for CDP port-map profile isolation (Issue #244)."""
  2 |
  3 | from __future__ import annotations
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#555 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/test_cdp_profile_owned_close.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | from notebooklm_tools.utils import cdp
  2 | ...
  3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#556 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/test_cdp_proxy_bypass.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """CDP WebSocket must not use HTTP*_PROXY for localhost (Issue #119, PR #157)."""
  2 |
  3 | import os
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#557 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/test_cdp_url_check.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Regression tests for ``is_logged_in()`` URL detection.
  2 |
  3 | Background: ``is_logged_in(url)`` previously used a substring match
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#558 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/test_coerce_list.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for MCP tools coerce_list utility."""
  2 |
  3 | import pytest
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#559 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/test_config_home_dir.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | from __future__ import annotations
  2 | ...
  3 | import importlib
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#560 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/test_cookie_parsing.py:17](#)

High-risk permission pattern: with tempfile.NamedTemporaryFile(mode="w", suffix=".json", delete=False) as f:

```
15 | def test_parse_json_dict():
16 |     """JSON dict format: {"name": "value"}."""
> 17 |     with tempfile.NamedTemporaryFile(mode="w", suffix=".json", delete=False) as f:
18 |         json.dump({"SID": "abc123", "HSID": "def456"}, f)
19 |         path = f.name
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#561 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/test_cookie_parsing.py:46](#)

High-risk permission pattern: with tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False) as f:

```
44 | def test_parse_netscape_format():
45 |     """Netscape cookie file with tab-separated fields."""
> 46 |     with tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False) as f:
47 |         f.write(SAMPLE_NETSCAPE)
48 |         path = f.name
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#562 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/test_cookie_parsing.py:68](#)

High-risk permission pattern: with tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False) as f:

```
66 |     from notebooklm_tools.utils.browser import validate_notebooklm_cookies
67 |
> 68 |     with tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False) as f:
69 |         f.write(SAMPLE_NETSCAPE)
70 |         path = f.name
```


Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#563 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/test_cookie_parsing.py:86](#)

High-risk permission pattern: with tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False) as f:

```
84 |  
85 | """  
> 86 |     with tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False) as f:  
87 |         f.write(content)...  
88 |         path = f.name
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#564 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/test_cookie_parsing.py:99](#)

High-risk permission pattern: with tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False) as f:

```
97 |     """Content with tabs but not 7+ fields per line falls through."""  
98 |     content = "just\ta\tfew\tfields\nnot\tenough"  
> 99 |     with tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False) as f:  
100 |         f.write(content)  
101 |         path = f.name
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#565 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/test_cookie_parsing.py:114](#)

High-risk permission pattern: with tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False) as f:

```
112 | def test_parse_cookie_header():  
113 |     """Standard Cookie header format."""  
> 114 |     with tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False) as f:  
115 |         f.write("Cookie: SID=abc; HSID=def; SSID=ghi")  
116 |         path = f.name
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#566 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/test_cookie_parsing.py:126](#)

High-risk permission pattern: with tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False) as f:

```
124 | def test_parse_name_value_pairs():
125 |     """Plain name=value pairs separated by semicolons."""
> 126 |     with tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False) as f:
127 |         f.write("SID=abc; HSID=def; SSID=ghi")...
128 |         path = f.name
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#567 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/test_cookie_parsing.py:150](#)

High-risk permission pattern: with tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False) as f:

```
148 |         "#HttpOnly_.google.com\tTRUE\t\tTRUE\t1812953356\t__Secure-1PSIDTS\tsecure-value-123\n"
149 |     )
> 150 |     with tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False) as f:
151 |         f.write(content)
152 |         path = f.name
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#568 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/test_cookie_parsing.py:166](#)

High-risk permission pattern: with tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False) as f:

```
164 |         "#HttpOnly_.google.com\tTRUE\t\tTRUE\t1812953356\t__Secure-3PSIDTS\tsecure-value\n"
165 |     )
> 166 |     with tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False) as f:
167 |         f.write(content)
168 |         path = f.name
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#569 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/test_cookie_parsing.py:179](#)

High-risk permission pattern: with tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False) as f:

```
177 |         """Cookies with empty values should be parsed with an empty string value."""
178 |         content = ".google.com\tTRUE\t\tFALSE\t1812953356\tEMPTY_COOKIE\t\n"
> 179 |         with tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False) as f:
180 |             f.write(content)
181 |             path = f.name
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#570 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/test_cookie_parsing.py:192](#)

High-risk permission pattern: with `tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False)` as f:

```
190 |         """Cookie values that contain tabs internally are joined and parsed fully."""
191 |         content = ".google.com\\tTRUE\\t\\tFALSE\\t1812953356\\tTAB_COOKIE\\tvalue\\twith\\ttabs\\n"
> 192 |         with tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False) as f:
193 |             f.write(content)...
194 |             path = f.name
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#571 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/test_cookie_parsing.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for cookie parsing from files (Netscape format support)."""
2 |
3 | import json
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#572 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/test_debug_artifacts.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | import importlib.util
2 | import subprocess
3 | from pathlib import Path
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#573 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/test_debug_page_permissions.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Regression test for the debug_page.html dump permissions.
    2 | ...
    3 | Covers GHSA-747w-q55c-m74m: the dump was written with the process umask and
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#574 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/test_download_integration.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Integration tests for Download functionalities.
    2 |
    3 | Targeting Notebook: 4085e211-fdb0-4802-b973-b43b9f99b6f7
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#575 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/test_e2e.py:66](#)

High-risk permission pattern: notebook = client.create_notebook(title="E2E Delete Test")

```
64 |         """Test creating and deleting a notebook."""
65 |         # Create
> 66 |         notebook = client.create_notebook(title="E2E Delete Test")
67 |         assert notebook is not None
68 |         assert notebook.id is not None
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#576 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/test_e2e.py:69](#)

High-risk permission pattern: assert "E2E Delete Test" in notebook.title

```
67 |         assert notebook is not None
68 |         assert notebook.id is not None
> 69 |         assert "E2E Delete Test" in notebook.title
70 |
71 |         # Delete
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#577 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/test_e2e.py:71](#)

High-risk permission pattern: # Delete

```
69 |         assert "E2E Delete Test" in notebook.title
70 |
> 71 |         # Delete
72 |         result = client.delete_notebook(notebook.id)...
73 |         assert result is True
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#578 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/test_e2e.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """End-to-end tests for NotebookLM Tools.
2 |
3 | These tests run against the real NotebookLM API using cached credentials.
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#579 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[tests/test_file_upload.py:99](#)

Potential secret: possible hardcoded secret

```
97 |         client = SourceMixin.__new__(SourceMixin)
98 |         client.cookies = {"test": "cookie"}
> 99 |         client.csrf_token = "test-csrf"
100 |         client._session_id = "test-session"
101 |         client._client = None
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#580 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[tests/test_file_upload.py:124](#)

Potential secret: possible hardcoded secret

```
122 |         client = SourceMixin.__new__(SourceMixin)
123 |         client.cookies = {"test": "cookie"}
> 124 |         client.csrf_token = "test-csrf"
125 |         client._session_id = "test-session"
126 |         client._client = None
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#581 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[tests/test_file_upload.py:147](#)

Potential secret: possible hardcoded secret

```
145 |         client = SourceMixin.__new__(SourceMixin)
146 |         client.cookies = {"test": "cookie"}
> 147 |         client.csrf_token = "test-csrf"
148 |         client._session_id = "test-session"...
149 |         client._client = None
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#582 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[tests/test_file_upload.py:178](#)

Potential secret: possible hardcoded secret

```
176 |         client = SourceMixin.__new__(SourceMixin)
177 |         client.cookies = {"test": "cookie"}
> 178 |         client.csrf_token = "test-csrf"
179 |         client._session_id = "test-session"
180 |         client._client = None
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#583 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[tests/test_file_upload.py:208](#)

Potential secret: possible hardcoded secret

```
206 |         client = SourceMixin.__new__(SourceMixin)
207 |         client.cookies = {"test": "cookie"}
> 208 |         client.csrf_token = "test-csrf"
209 |         client._session_id = "test-session"
210 |         client._client = None
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#584 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[tests/test_file_upload.py:248](#)

Potential secret: possible hardcoded secret

```
246 |         client = SourceMixin.__new__(SourceMixin)
247 |         client.cookies = {"test": "cookie"}
> 248 |         client.csrf_token = "test-csrf"
249 |         client._session_id = "test-session"...
250 |         client._client = None
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#585 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[tests/test_file_upload.py:287](#)

Potential secret: possible hardcoded secret

```
285 |         client = SourceMixin.__new__(SourceMixin)
286 |         client.cookies = {"test": "cookie"}
> 287 |         client.csrf_token = "test-csrf"
288 |         client._session_id = "test-session"
289 |         client._client = None
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#586 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/test_file_upload.py:45](#)

High-risk permission pattern: with tempfile.NamedTemporaryFile(suffix=".txt", delete=False) as f:

```
43 |         client._client = None
44 |
> 45 |         with tempfile.NamedTemporaryFile(suffix=".txt", delete=False) as f:
46 |             temp_path = f.name
47 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#587 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/test_file_upload.py:79](#)

High-risk permission pattern: with tempfile.NamedTemporaryFile(mode="w", suffix=".json", delete=False) as f:

```
77 |
78 |         # Create a JSON file (unsupported type)
> 79 |         with tempfile.NamedTemporaryFile(mode="w", suffix=".json", delete=False) as f:
80 |             f.write('{"test": "data"}')
81 |             temp_path = f.name
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#588 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/test_file_upload.py:213](#)

High-risk permission pattern: with tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False) as f:

```
211 |  
> 212 |         # Create a temporary test file  
213 |         with tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False) as f:  
214 |             f.write("Test content for upload")...  
215 |             temp_path = Path(f.name)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#589 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/test_file_upload.py:253](#)

High-risk permission pattern: with tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False) as f:

```
251 |  
> 252 |         # Create a test file  
253 |         with tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False) as f:  
254 |             f.write("Test content")  
255 |             temp_path = Path(f.name)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#590 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/test_file_upload.py:291](#)

High-risk permission pattern: with tempfile.NamedTemporaryFile(mode="wb", suffix=".epub", delete=False) as f:

```
289 |         client._client = None  
> 290 |  
291 |         with tempfile.NamedTemporaryFile(mode="wb", suffix=".epub", delete=False) as f:  
292 |             f.write(b"PK\x03\x04fake epub content")  
293 |             temp_path = Path(f.name)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#591 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/test_file_upload.py:324](#)

High-risk permission pattern: with tempfile.NamedTemporaryFile(mode="wb", suffix=suffix, delete=False) as f:

```
322 |  
323 |         client = SourceMixin.__new__(SourceMixin)  
> 324 |         with tempfile.NamedTemporaryFile(mode="wb", suffix=suffix, delete=False) as f:  
325 |             f.write(b"test content")...  
326 |             temp_path = Path(f.name)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#592 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/test_file_upload.py:369](#)

High-risk permission pattern: with tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False) as f:

```
367 |         )  
368 |  
> 369 |         with tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False) as f:  
370 |             f.write("Test content for NotebookLM upload.")  
371 |             temp_path = f.name
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#593 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/test_file_upload.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for file upload functionality."""  
2 |  
3 | import inspect
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#594 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[tests/test_io_encoding_windows.py:37](#)

Dangerous execution: with __import__("pytest").raises(UnicodeEncodeError):

```
35 |  
36 |         stream = io.TextIOWrapper(io.BytesIO(), encoding="cp1252", errors="strict")  
> 37 |         with __import__("pytest").raises(UnicodeEncodeError):  
38 |             stream.write("\u2192")  
39 |
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#595 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/test_io_encoding_windows.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Windows stdio UTF-8 bootstrap (Issue #156)."""
   2 | ...
   3 | import sys
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include `agent_id`, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#596 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/test_log_redaction.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Regression tests for MCP debug log redaction.
   2 |
   3 | Covers GHSA-jhrc-qgxv-3c2g: requests were sanitized but responses were
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include `agent_id`, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#597 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/test_mcp_auth_studio_failures.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Regression tests for the P1 auth/studio silent-failure bug (Netter bug report 2026-06-01).
   2 |
   3 | Bug: under stale/expired auth, `refresh_auth()` returns status:"success" (it only
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include `agent_id`, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#598 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/test_mcp_chat.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for MCP chat tool wrappers."""
   2 |
   3 | import asyncio
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#599 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/test_mcp_downloads.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Unit tests for the download_all_artifacts MCP tool."""
  2 | ...
  3 | from unittest.mock import AsyncMock, MagicMock, patch
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#600 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/test_mcp_e2e.py:79](#)

High-risk permission pattern: result = mcp_tools["notebooks"].notebook_create(title="MCP Delete Test")

```
77 | """Test full notebook lifecycle."""
78 | # Create
> 79 | result = mcp_tools["notebooks"].notebook_create(title="MCP Delete Test")
80 | assert result["status"] == "success"
81 | notebook_id = result["notebook_id"]
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#601 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/test_mcp_e2e.py:87](#)

High-risk permission pattern: # Delete

```
85 | assert result["status"] == "success"
86 |
> 87 | # Delete
88 | result = mcp_tools["notebooks"].notebook_delete(notebook_id, confirm=True)
89 | assert result["status"] == "success"
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#602 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/test_mcp_e2e.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """End-to-end tests for MCP Server Tools.
    2 | ...
    3 | Tests the consolidated MCP tools against the real NotebookLM API.
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#603 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/test_mcp_file_upload.py:23](#)

High-risk permission pattern: with tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False) as f:

```
> 21 |
    22 |         # Create a test file
    23 |         with tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False) as f:
    24 |             f.write("Test content")
    25 |             temp_path = f.name
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#604 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/test_mcp_file_upload.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for MCP file upload functionality via consolidated source_add."""
    2 |
    3 | import tempfile
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#605 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/test_mcp_server_capabilities.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for conservative server capability reporting."""
    2 |
    3 | from unittest.mock import patch
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#606 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/test_mcp_sharing.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Agent-facing sharing errors preserve useful provider context."""
  2 | ...
  3 | from unittest.mock import MagicMock, patch
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#607 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/test_mcp_sources.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for MCP source tools."""
  2 |
  3 | from unittest.mock import MagicMock, patch
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#608 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/test_mcp_studio.py:216](#)

High-risk permission pattern: result = studio.report(notebook_id="nb", artifact_id="rep", action="delete")

```
214 |
215 | def test_report_rejects_unknown_action():
> 216 |     result = studio.report(notebook_id="nb", artifact_id="rep", action="delete")
    217 |     assert result["status"] == "error"
    218 |     assert "get, elements, generate" in result["error"]
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#609 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/test_mcp_studio.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Unit tests for MCP studio tools."""
  2 |
  3 | from unittest.mock import MagicMock, patch
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#610 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/test_mcp_usage.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Profile selection must not switch the MCP server's shared account."""
  2 | ...
  3 | from unittest.mock import MagicMock, patch
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#611 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/test_profile_aware_headless_auth.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Regression tests for profile-aware headless auth refresh."""
  2 |
  3 | from types import SimpleNamespace
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#612 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[tests/test_profile_cache_isolation.py:37](#)

Potential secret: possible hardcoded secret

```
35 | client = get_client("tsm")
36 | client.cookies = {"SID": "account-B-refreshed"}
> 37 | client.csrf_token = "csrf-b-refreshed"
38 | client._session_id = "session-b-refreshed"
39 | client._update_cached_tokens()
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#613 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/test_profile_cache_isolation.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Regression tests for profile-scoped auth cache updates (Issue #284)."""
  2 |
  3 | import json
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#614 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[tests/test_research_polling.py:12](#)

Potential secret: possible hardcoded secret

```
10 |     cookies = {"SID": "test_sid"}
11 |     with patch.object(NotebookLMClient, "_refresh_auth_tokens"):
> 12 |         client = NotebookLMClient(cookies=cookies, csrf_token="old_token", session_id="old_sid")
13 |         return client...
14 |
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#615 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/test_research_polling.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | from unittest.mock import patch
2 |
3 | import pytest
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#616 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/test_snap.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for snap browser detection and profile directory routing."""
2 |
3 | from pathlib import Path
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#617 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/test_tool_groups.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for optional MCP tool-group gating."""
2 |
3 | from unittest.mock import MagicMock
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#618 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/test_wsl.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for WSL networking utilities."""
  2 | ...
  3 | import subprocess
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#619 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

[tests/test_wsl_firewall_scope.py:41](#)

File input near prompt/instruction handling — injection vector

```
39 |
40 |
> 41 | def test_privilege_fallback_command_is_not_wide_open(_wsl_env, monkeypatch):
42 |     monkeypatch.setattr(
43 |         wsl.subprocess, "run", Mock(return_value=_run_result(1, "Access is denied"))
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#620 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/test_wsl_firewall_scope.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Regression tests for WSL firewall rule scoping.
  2 |
  3 | Covers GHSA-v558-4774-r6wq: the CDP bridge listens on 0.0.0.0, so the Windows
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

Remediation Checklist

Prioritized by severity. Address CRITICAL items first.

Quick Win

`npm install mcp-secure`
Adds cryptographic passports, signed messages, tool verification, and audit logging.

CRITICAL (2)

- ☐ **AS-001: unsafe execution**
Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code).
- ☐ **AS-005: injection pattern**
Validate and sanitize all inputs with strict allowlists.

HIGH (5)

- ☐ **AS-008: excessive agency**
Implement mandatory human-in-the-loop for destructive operations (`delete`, `write`, `execute`, `send`).
- ☐ **AS-006: sandboxing**
Run all agent-generated code in Docker containers with `--network=none` and read-only filesystem.
- ☐ **AS-004: prompt injection**
Sanitize all file contents before injecting into prompts (strip control chars, limit length).
- ☐ **AS-011: data exfiltration**
Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains.
- ☐ **AS-002: secret scan**
Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv).

MEDIUM (2)

- ☐ **AS-010: logging monitoring**
Add structured logging (JSON) for every agent action, tool call, and decision.
- ☐ **AS-003: excessive permissions**
Apply principle of least privilege — grant only permissions the agent needs for its specific task.

LOW (1)

- ☐ **AS-007: supply chain**
Use lockfiles (`package-lock.json`, `poetry.lock`, `requirements.txt` with hashes).

Methodology & Standards

Scanner	mcps-audit v1.0.0
Rules Version	1.1.0
Scanned At	28/09/2026, 09:51:39
Report ID	MCPS-MUKNIJAZ

Referenced Standards

- OWASP MCP Top 10**
Security risks for Model Context Protocol servers and clients.
owasp.org/www-project-mcp-top-10
- OWASP Agentic AI Top 10**
Security risks for autonomous AI agents.
owasp.org/www-project-agentic-ai-top-10
- MCPS -- IETF Internet-Draft**
Cryptographic security layer for MCP: draft-sharif-mcps-secure-mcp.
datatracker.ietf.org/doc/draft-sharif-mcps-secure-mcp
- MITRE ATT&CK**
Adversary tactics and techniques knowledge base.
attack.mitre.org
- STRIDE Threat Model**
Microsoft threat classification framework.
microsoft.com/en-us/security/blog/stride

AgentSign
Cryptographic identity and security for AI agents
agentsign.dev